

COMPTIA CERTIFIED | EXAM CODE: CS0-003

CompTIA

CySA+

CS0-003

300 Interview Q&A – Cybersecurity Analyst+

Complete exam preparation covering all SY0-701 exam domains:

Threat Intel | Vuln Management | SIEM | Incident Response

Forensics | Cloud Security | Malware Analysis | Threat Hunting

300

Questions

17

Sections

CS0-003

Exam Code

750/900

Pass Score

Table of Contents

CompTIA CySA+ CS0-003 – Complete Interview Preparation Guide

#	Section	Key Topics	Q's
1	Threat Intelligence & Threat Hunting	TTP, IoC, STIX/TAXII, Diamond Model, ATT&CK, TIP, pivoting	23
2	Vulnerability Management	CVSS, EPSS, KEV, authenticated scanning, SCA, SAST, DAST	23
3	Security Operations & SIEM	SIEM, correlation rules, UEBA, NTA, alert triage, MTTD/MTTR	23
4	Incident Response	IR phases, containment, eradication, forensic preservation	21
5	Network Security Analysis	Wireshark, NetFlow, protocol analysis, beaconing, DNS analysis	21
6	Endpoint Security Analysis	EDR telemetry, process tree, Windows Event IDs, LOLBins, Sysmon	19
7	Digital Forensics	Forensic imaging, Autopsy, Volatility, timeline, chain of custody	16
8	Cloud Security Analysis	CloudTrail, GuardDuty, CSPM, Kubernetes, cloud IR, SIEM cloud	14
9	Identity & Access Analysis	Active Directory, Kerberoasting, BloodHound, MFA bypass, PAM	14
10	Malware Analysis	Static/dynamic analysis, YARA, C2, sandbox, malware classification	15
11	Security Automation & SOAR	SOAR playbooks, API integration, threat enrichment, automation	15
12	Risk Management & Compliance	Risk quantification, compliance gap analysis, GRC, audit response	15
13	Application Security Analysis	OWASP Top 10, web app pen test, SAST, DAST, API testing, SSRF	15
14	CySA+ CS0-003 Exam Focus	CS0-003 format, PBQs, domains, study approach, exam strategy	16
15	Reporting & Communication	Executive reporting, metrics, incident report, vuln disclosure	16
16	Advanced Threat Detection Techniques	Deception, ML detection, Sigma, behavioral vs signature, BAS	18
17	Scenario-Based & Practical	Scenario IR, threat hunting, cloud misconfiguration, forensics	16

200	16	003	~70%
Total Questions	Sections	Exam Code	Passing Score

1 Threat Intelligence & Threat Hunting

23 Qs

Q1 QUESTION

What is threat intelligence?

ANSWER

Threat intelligence is evidence-based knowledge about adversary TTPs, motivations, and indicators used to make informed security decisions. Example: Knowing APT29 uses spear phishing with malicious LNK files allows a defender to create email gateway rules blocking .lnk attachments before the campaign hits their organization.

Q2 QUESTION

What are the types of threat intelligence?

ANSWER

Strategic: high-level trends for executives — 'Nation-state actors are targeting financial sector.' Operational: campaign-level details — 'FIN7 is using a new PowerShell loader.' Tactical: technical IoCs — IP 185.220.101.x, hash alB2c3d4, domain evil.com. Technical: feeds of raw IoCs for automated ingestion. Each serves a different audience and use case.

Q3 QUESTION

What is the intelligence cycle?

ANSWER

The intelligence cycle converts raw data into actionable intelligence: (1) Planning & Direction — define requirements (what threats matter to us?); (2) Collection — gather from OSINT, HUMINT, technical feeds; (3) Processing — normalize and aggregate data; (4) Analysis — correlate, contextualize, assess confidence; (5) Dissemination — share with stakeholders; (6) Feedback — refine requirements. Example: SOC needs to know if APT28 is targeting their sector; the cycle produces a tailored threat report.

Q4 QUESTION

What is OSINT?

ANSWER

Open Source Intelligence collects from publicly available sources. Example: Using Maltego to map relationships between a suspicious domain: WHOIS reveals registration email, Shodan shows open ports and certificates, VirusTotal shows associated malware, PassiveTotal shows historical DNS records. All from public sources, no interaction with the target.

Q5 QUESTION

What is threat hunting?

ANSWER

Threat hunting proactively searches for adversaries that have evaded automated detection. Unlike alert-based response (reactive), hunting is hypothesis-driven. Example: Hunter hypothesizes 'Attackers may be using DNS tunneling for C2.' Queries: DNS requests with TXT records longer than 100 characters, high query frequency to single domain, base64-encoded subdomains. Result: Discovers compromised host beaconing via DNS.

Q6 QUESTION

What is a threat hunting hypothesis?

ANSWER

A hypothesis is a testable, specific assumption about adversary behavior based on threat intelligence. Good hypothesis example: 'Based on CISA advisory AA23-075A, TA577 uses ProxyShell (CVE-2021-34473) for initial access — we may have vulnerable Exchange servers with webshell backdoors.' Bad hypothesis: 'We might be hacked.' Hypotheses come from: threat intel, MITRE ATT&CK, past incidents, vulnerability disclosures.

Q7 QUESTION

What is the MITRE ATT&CK; framework?

ANSWER

MITRE ATT&CK; is a knowledge base of real-world adversary tactics and techniques organized as a matrix. Tactics (the why): Initial Access, Execution, Persistence, Privilege Escalation, Defense Evasion, Credential Access, Discovery, Lateral Movement, Collection, C2, Exfiltration, Impact. Techniques (the how): T1566 Phishing, T1059 Command Scripting Interpreter. Example: Mapping a detected attack to ATT&CK; identifies coverage gaps in defenses.

Q8 QUESTION

What is STIX and TAXII?

ANSWER

STIX (Structured Threat Information eXpression) is a standardized JSON-based language for describing threat intelligence objects (indicators, campaigns, threat actors, attack patterns). TAXII (Trusted Automated eXchange of Indicator Information) is the transport protocol for sharing STIX data. Example: FS-ISAC shares a STIX bundle of banking trojan IoCs via TAXII — member banks automatically ingest and block the indicators.

Q9 QUESTION

What is a TTP (Tactic, Technique, Procedure)?

ANSWER

TTPs describe how adversaries operate. Tactic: the objective (Credential Access). Technique: the method (T1110 Brute Force). Procedure: the specific implementation (using Hydra to brute force SSH with rockyou.txt wordlist). TTPs are more durable than IoCs — adversaries change IPs and domains daily but rarely change core TTPs. Detection based on TTPs is more effective long-term.

Q10 QUESTION

What is threat intelligence enrichment?

ANSWER

Enrichment adds context to raw IoCs to make them actionable. Example: Raw IoC: IP 185.234.x.x. Enriched: IP resolves to known Tor exit node (AbuseIPDB), registered to bulletproof hosting provider (Shodan), associated with 47 malware samples (VirusTotal), appears in threat feeds for Cobalt Strike C2 (AlienVault OTX). Enriched IoC has high confidence — block and alert.

Q11 QUESTION

What is a diamond model of intrusion analysis?

ANSWER

The Diamond Model describes intrusions using four core features: Adversary (who), Capability (malware/tool), Infrastructure (IP, domain), Victim (target). Edges connect: Adversary uses Capability over Infrastructure against Victim. Example: APT10 (Adversary) uses ChChes RAT (Capability) via compromised MSP infrastructure (Infrastructure) against aerospace firms (Victim). Meta-features: timestamp, phase, result, direction, methodology.

Q12 QUESTION

What is threat intelligence confidence levels?

ANSWER

Confidence levels quantify certainty about intelligence. MISP uses a 0-100% scale. Admiralty Scale rates source reliability (A-F) and information credibility (1-6). Example: A=completely reliable source, 1=confirmed by other sources □ high confidence. F=reliability unknown, 6=truth cannot be judged □ low confidence. Only high-confidence intelligence should trigger automated blocking; low confidence informs monitoring.

Q13 QUESTION

What is a threat intelligence platform (TIP)?

ANSWER

A TIP aggregates, normalizes, and manages threat intelligence from multiple sources. Examples: MISP (open source), Anomali ThreatStream, ThreatConnect, Recorded Future. Functions: ingest feeds (STIX/TAXII, CSV, JSON), deduplicate IoCs, enrich with context, score by relevance, export to security controls (SIEM, firewall, EDR). Example: MISP automatically pushes new C2 IoCs to Palo Alto firewall and Splunk.

Q14 QUESTION

What is active vs passive threat hunting?

ANSWER

Passive hunting analyzes existing data (logs, alerts) without generating new traffic — lower detection risk. Example: Hunting through 90 days of proxy logs for beaconing patterns. Active hunting generates network traffic to probe systems — may alert sophisticated adversaries. Example: Using nmap to verify whether suspected compromised hosts have unexpected listening ports. Both are valid; passive is safer.

Q15 QUESTION

What is a hunting maturity model?

ANSWER

The Hunting Maturity Model (HMM) measures hunting capability: Level 0 (Initial) — no hunting, dependent on automated alerts; Level 1 (Minimal) — uses threat intel feeds; Level 2 (Procedural) — follows documented hunt procedures; Level 3 (Innovative) — creates custom analytics; Level 4 (Leading) — automates hunting, generates new TTPs. Most organizations are at Level 1-2. Goal is Level 3-4.

Q16 QUESTION

What is pivoting in threat intelligence?

ANSWER

Pivoting uses one piece of intelligence to discover related indicators. Example: Starting with a malicious IP 185.234.x.x: pivot on SSL certificate (same cert used on 5 other IPs) □ pivot on WHOIS email (registrant email used on 20 domains) □ pivot on file hash (malware submitted from related IP). Each pivot expands the known adversary infrastructure. Tools: Maltego, PassiveTotal, RiskIQ.

Q17 QUESTION

What are threat intelligence sharing communities?

ANSWER

ISACs (Information Sharing and Analysis Centers) share sector-specific intelligence: FS-ISAC (financial), H-ISAC (healthcare), E-ISAC (energy), Auto-ISAC (automotive). ISAOs (Information Sharing and Analysis Organizations) are sector-agnostic. US-CERT/CISA shares government intelligence. Sharing principles: Traffic Light Protocol (TLP) defines distribution limits: TLP:RED (recipient only), TLP:AMBER (limited sharing), TLP:GREEN (community), TLP:WHITE (public).

Q18 QUESTION

What is TLP (Traffic Light Protocol)?

ANSWER

TLP controls threat intelligence sharing. TLP:RED — not for disclosure, recipient only. TLP:AMBER — limited disclosure to need-to-know within organization (or clients). TLP:AMBER+STRICT — recipient organization only, not clients. TLP:GREEN — community-wide sharing, not public. TLP:CLEAR (formerly WHITE) — publicly shareable. Example: CISA shares a critical advisory as TLP:AMBER — you can share internally but not post on Twitter.

Q19 QUESTION

What is indicator lifecycle management?

ANSWER

IoC lifecycle: (1) Creation — indicator first observed; (2) Verification — confirmed malicious; (3) Dissemination — shared with defenses; (4) Expiration — IoCs age out (IPs change ownership, domains expire). Active management: IP IoCs expire in 30 days, domains 60-90 days, file hashes 1 year. Stale IoCs cause false positives. Platforms like MISP track IoC age and automatically expire them.

Q20 QUESTION

What is threat modeling for threat hunting?

ANSWER

Threat modeling for hunting identifies the most likely attack paths before hunting begins. Steps: (1) Profile your organization (sector, data, systems); (2) Identify relevant threat actors and their TTPs; (3) Map TTPs to your environment (which systems are targeted?); (4) Prioritize hunting based on likelihood and impact; (5) Define success criteria. Example: Healthcare org profiles ransomware groups targeting hospitals ▢ hunts for Ryuk precursor activity (Emotet, TrickBot).

Q21 QUESTION

What is cyber threat intelligence (CTI) analyst role?

ANSWER

CTI analyst responsibilities: (1) Monitor threat landscape — track emerging threats, vulnerabilities, attacker TTPs; (2) Produce intelligence reports — strategic, operational, technical; (3) Hunt for relevant threats using threat intelligence leads; (4) Manage threat intel platform — feed curation, IoC lifecycle; (5) Provide threat briefings to stakeholders; (6) Support incident response — attribute attacks, predict next moves; (7) Participate in intelligence sharing communities (ISAC, ISAO); (8) Develop detection content from threat reports. Skills: OSINT research, malware analysis basics, SIEM query writing, writing and communication, analytical thinking.

Q22 QUESTION

What is intelligence-driven security operations?

ANSWER

Intelligence-driven security operations uses threat intelligence to prioritize and focus security effort. Traditional: react to every alert equally. Intelligence-driven: understand which threats matter to your organization ▢ prioritize defenses against those specific threats ▢ tune SIEM to detect their TTPs ▢ hunt for their IoCs proactively ▢ design tabletop exercises around their playbooks. Example: Healthcare org learns APT40 is targeting healthcare for IP theft ▢ maps APT40 TTPs to ATT&CK; ▢ identifies detection gaps for APT40 techniques ▢ implements targeted detections ▢ hunts for APT40 IoCs in historical logs ▢ prepares specific IR playbook for APT40-style attack.

Q23 QUESTION

What is threat intelligence integration with IR?

ANSWER

TI integration with incident response: (1) Attribution support — does the attacker match known threat actor TTPs? Informs response urgency and scope; (2) Predictive action — knowing the actor's playbook predicts their next moves (e.g., Ryuk always deletes shadow copies — check for that activity); (3) IoC expansion — use one confirmed IoC to find more related infrastructure via TI platform pivot analysis; (4) Intelligence feedback — IR findings (new IoCs, TTPs) fed back to TI team for future alerts; (5) War room support — TI analyst embedded in IR team during major incidents provides real-time contextual intelligence. Example: Confirming Conti group ▢ apply known Conti eradication checklist, including specific persistence locations and lateral movement paths.

2 Vulnerability Management

23 Qs

Q24 QUESTION

What is vulnerability management lifecycle?

ANSWER

VM lifecycle: (1) Asset Discovery — inventory all assets (Nmap, CMDB); (2) Vulnerability Scanning — identify CVEs (Nessus, Qualys); (3) Prioritization — score by CVSS + context; (4) Remediation — patch, mitigate, or accept; (5) Verification — rescan to confirm fix; (6) Reporting — metrics for management. Continuous process — not a one-time project.

Q25 QUESTION

What is CVSS and its components?

ANSWER

CVSS (Common Vulnerability Scoring System) v3.1 scores 0-10. Base metrics: Attack Vector (Network/Adjacent/Local/Physical), Attack Complexity (Low/High), Privileges Required (None/Low/High), User Interaction (None/Required), Scope (Changed/Unchanged), Confidentiality/Integrity/Availability Impact (None/Low/High). Example: Log4Shell = CVSS 10.0 — AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H.

Q26 QUESTION

What is CVSS vs EPSS?

ANSWER

CVSS measures severity of a vulnerability in isolation. EPSS (Exploit Prediction Scoring System) predicts the probability a vulnerability will be exploited in the wild within 30 days. Example: A CVSS 9.0 vulnerability with EPSS 0.02% (rarely exploited) may be deprioritized. A CVSS 6.0 with EPSS 85% (actively exploited) should be patched urgently. Use EPSS + CVSS + CISA KEV for smarter prioritization.

Q27 QUESTION

What is CISA KEV catalog?

ANSWER

CISA Known Exploited Vulnerabilities (KEV) catalog lists vulnerabilities with confirmed active exploitation. US federal agencies must patch KEV entries within defined timeframes (2 weeks for critical). Example: CVE-2023-34362 (MOVEit SQL injection) was added to KEV after Cl0p ransomware group mass-exploited it. KEV membership overrides CVSS score — a KEV CVSS 5.0 is higher priority than a non-KEV CVSS 9.0.

Q28 QUESTION

What is authenticated vs unauthenticated scanning?

ANSWER

Unauthenticated scan: external view without credentials — finds exposed services, open ports, banner information. Misses: OS-level vulns, patch levels, local configurations. Authenticated scan: uses credentials (domain account, SSH key) — finds installed software versions, missing patches, local misconfigurations. Example: Nessus authenticated scan finds CVE-2021-34527 (PrintNightmare) on a Windows server — unauthenticated scan would miss this.

Q29 QUESTION

What is vulnerability prioritization?

ANSWER

Prioritization considers: CVSS score, EPSS probability, CISA KEV membership, asset criticality (crown jewel vs test server), exploitability (public PoC available?), compensating controls (WAF present?), exposure (internet-facing vs internal). Example: Framework — critical (CVSS 9+, KEV, internet-facing) □ patch in 24h; high (CVSS 7+, PoC, critical asset) □ 7 days; medium (CVSS 4+, internal, no PoC) □ 30 days.

Q30 QUESTION

What is a vulnerability scanner and how does it work?

ANSWER

Vulnerability scanners compare installed software and configurations against CVE/NVD databases and plugin checks. Nessus: sends crafted packets, analyzes responses, checks version strings. Example: Nessus plugin 153953 checks if Apache Log4j version is ≤ 2.14.1 (vulnerable to CVE-2021-44228) by reading the JAR manifest or HTTP headers. Results: CVE ID, CVSS, description, solution (patch version).

Q31 QUESTION

What is a false positive vs false negative in vulnerability scanning?

ANSWER

False positive: scanner reports a vulnerability that doesn't actually exist. Example: Scanner reports Apache 2.4.49 vulnerability but the server has the patch backported — appears vulnerable by version but isn't. False negative: scanner misses a real vulnerability. Example: Custom application with SQLi vulnerability — scanner doesn't know the app's logic. Impact: FP wastes remediation resources; FN leaves real risk unaddressed.

Q32 QUESTION

What is patch management and its relation to vulnerability management?

ANSWER

Patch management is the operational process of testing and deploying patches to remediate vulnerabilities. VM identifies what needs patching; PM executes the fix. Metrics: patch compliance rate (% of systems patched within SLA), mean time to patch (MTTP). Example: VM scan finds 200 critical CVEs across 50 servers □ PM creates tickets, tests in staging, deploys via SCCM/Ansible, VM rescans to verify □ 198/200 remediated, 2 accepted with compensating controls.

Q33 QUESTION

What is a vulnerability exceptions process?

ANSWER

When a vulnerability cannot be immediately patched, a formal exception is documented: vulnerability ID, affected system, reason for exception (legacy dependency, vendor delay), compensating control (WAF rule, network isolation), risk acceptance by owner, review date. Example: Oracle database on Windows 2003 (EOL) — cannot patch; exception: isolate to management VLAN, firewall to DB port only, quarterly review, plan migration to supported OS within 6 months.

Q34 QUESTION

What is SAST vs DAST in vulnerability context?

ANSWER

SAST (Static Application Security Testing): analyzes source code without execution — finds issues early in SDLC. Tools: Checkmarx, Sengrep, SonarQube. DAST (Dynamic Application Security Testing): tests running application by sending malicious inputs. Tools: Burp Suite, OWASP ZAP. Combine in CI/CD: SAST in dev pipeline, DAST in staging. Example: SAST finds hardcoded API key; DAST finds XSS in a dynamically generated page SAST couldn't see.

Q35 QUESTION

What is SCA (Software Composition Analysis)?

ANSWER

SCA identifies vulnerabilities in third-party and open-source dependencies. Example: A Python application uses requests==2.18.4 (CVE-2018-18074 – redirect vulnerability) and PyYAML==3.12 (CVE-2017-18342 – arbitrary code execution). SCA tools (Snyk, OWASP Dependency-Check, Black Duck) detect these and recommend upgraded versions. Critical as 80%+ of modern app code is open source.

Q36 QUESTION

What is continuous vulnerability management?

ANSWER

Continuous VM replaces point-in-time quarterly scans with ongoing scanning and monitoring. Components: agent-based scanning (Tenable.io agent runs continuously on each endpoint), cloud-native scanning (AWS Inspector continuously monitors EC2 instances), runtime scanning (Qualys VMDR detects new CVEs for installed software without rescanning). Mean time to detect new vulnerabilities reduces from weeks to hours.

Q37 QUESTION

What is a vulnerability disclosure policy?

ANSWER

A vulnerability disclosure policy defines how the organization handles reports of vulnerabilities in their systems. Responsible disclosure (coordinated): researcher reports privately, org has time to patch, then disclosure. Bug bounty programs (HackerOne, Bugcrowd) incentivize researchers. Example: researcher finds SQLi in company's API, reports via HackerOne – company acknowledges in 24h, patches in 14 days, pays \$5,000 bounty, researcher publishes post-patch write-up.

Q38 QUESTION

What is attack surface management (ASM)?

ANSWER

ASM continuously discovers and monitors all internet-exposed assets for vulnerabilities and misconfigurations. Example: A company knows about 50 internet-facing systems but ASM tool (Censys, Expanse) discovers 12 more – shadow IT, old dev servers, forgotten cloud instances. These unmanaged assets are often the most vulnerable. ASM correlates discovered assets with CVE data to prioritize remediation.

Q39 QUESTION

What is a CVE vs CWE vs CCE?

ANSWER

CVE (Common Vulnerabilities and Exposures): specific instance – CVE-2021-44228 (Log4Shell in Log4j 2.x). CWE (Common Weakness Enumeration): vulnerability class/type – CWE-502 (Deserialization of Untrusted Data), CWE-79 (XSS). CCE (Common Configuration Enumeration): security configuration issues – CCE-10087-3 (Windows password policy setting). CVEs reference CWEs to categorize root cause.

Q40 QUESTION

What is risk-based vulnerability management?

ANSWER

Risk-based VM considers business context alongside technical severity. Factors: asset business criticality (payment processing server vs dev workstation), data sensitivity (PII vs public info), threat intelligence (is this CVE being actively exploited?), compensating controls (WAF, network isolation). Example: CVSS 7.0 on internet-facing payment server with no WAF = critical priority. Same CVSS on isolated internal dev server = low priority.

Q41 QUESTION

What is vulnerability remediation SLA?

ANSWER

SLA defines maximum time to patch based on severity. Example SLA framework: Critical (CVSS 9-10, KEV) □ 24-72 hours; High (CVSS 7-8.9) □ 7 days; Medium (CVSS 4-6.9) □ 30 days; Low (CVSS 0.1-3.9) □ 90 days. SLA compliance is a key security metric. Exception process for SLA breaches. Tracked in vulnerability management tools (Tenable, Qualys) with ticketing integration.

Q42 QUESTION

What is compensating control in vulnerability management?

ANSWER

A compensating control reduces risk when direct remediation isn't possible. Example: Vulnerability CVE-2023-XXXX in Oracle Forms (can't patch — vendor delay). Compensating controls: (1) WAF rule blocking the exploit pattern; (2) Network ACL restricting access to authorized IPs only; (3) Enhanced monitoring for exploitation attempts; (4) Emergency change request to vendor. Document the compensating control and review quarterly.

Q43 QUESTION

What is vulnerability scanning scope and scheduling?

ANSWER

Scan scope: include all assets — on-premises, cloud, OT/ICS, containers, APIs. Scheduling: internet-facing systems — weekly or continuous; internal critical systems — weekly; internal standard systems — monthly; after major changes — immediately. Challenges: OT/ICS systems may crash on active scanning □ use passive scanning (traffic analysis). Cloud assets — use cloud-native scanners (AWS Inspector, Azure Defender).

Q44 QUESTION

What is risk scoring methodology?

ANSWER

Risk scoring combines multiple factors into a single prioritization score. Formula example: Risk Score = (CVSS × 0.4) + (EPSS × 100 × 0.3) + (Asset Criticality × 0.2) + (Exploit Public × 0.1). Example: CVE with CVSS 8.0, EPSS 45%, critical asset, public exploit = $(8.0 \times 0.4) + (45 \times 0.3) + (10 \times 0.2) + (10 \times 0.1) = 3.2 + 13.5 + 2.0 + 1.0 = 19.7$. CVE with CVSS 9.5, EPSS 0.1%, non-critical, no exploit = $(9.5 \times 0.4) + (0.1 \times 0.3) + (2 \times 0.2) + (0 \times 0.1) = 3.8 + 0.03 + 0.4 + 0 = 4.23$. EPSS drives the score — patch the first despite lower CVSS.

Q45 QUESTION

What is vulnerability intelligence?

ANSWER

Vulnerability intelligence monitors vulnerability disclosures to anticipate and respond quickly. Sources: NVD (NIST), vendor advisories (Microsoft Patch Tuesday, CISA advisories), security research blogs (Project Zero, ZDI), Twitter/X security researchers, CVE feeds, FIRST EPSS updates. Workflow: receive new CVE disclosure □ immediately assess: CVSS, EPSS, affected products (does our environment use this?), exploit availability □ if high risk □ emergency scan □ prioritize patching. Example: CVE-2023-34362 (MOVEit) released □ check environment □ 3 MOVEit instances found □ emergency patch within 24 hours (before CISA added to KEV).

Q46 QUESTION

What is vulnerability remediation verification?

ANSWER

Verification confirms vulnerabilities are actually fixed, not just marked resolved. Methods: (1) Rescan with same tool and version — compare findings to pre-remediation scan; (2) Authenticated vs unauthenticated verification — ensure both perspectives confirm fix; (3) Manual verification — test the specific exploit technique to confirm it no longer works; (4) Regression testing — verify fix didn't break application functionality; (5) DAST rescan — for web application vulnerabilities, rescan with DAST tool. Documentation: attach rescan evidence to remediation ticket. Common failure: developers mark tickets resolved without fixing or fix wrong system — scanning-based verification catches this.

3 Security Operations & SIEM

23 Qs

Q47 QUESTION

What is a SOC and its functions?

ANSWER

A Security Operations Center provides 24/7 security monitoring and incident response. Functions: alert triage, threat detection, incident response, threat hunting, vulnerability management, threat intelligence, security engineering. Tiers: L1 (triage – follow playbook, escalate), L2 (investigation – deeper analysis, contain), L3 (advanced – threat hunting, custom detection, malware analysis). Metrics: MTTD, MTTR, alert volume, false positive rate.

Q48 QUESTION

What is SIEM and how does it work?

ANSWER

SIEM (Security Information and Event Management) centralizes log collection, correlation, and alerting. Architecture: (1) Log Sources (endpoints, network devices, apps) □ (2) Log Collection (agents, syslog, API) □ (3) Normalization (parse fields: timestamp, src_ip, dst_ip, user) □ (4) Correlation Engine (apply rules) □ (5) Alert □ (6) Case Management. Examples: Splunk, IBM QRadar, Microsoft Sentinel, Elastic SIEM.

Q49 QUESTION

What is log normalization?

ANSWER

Log normalization converts logs from different sources into a common schema. Example: Windows Event Log (XML format) and Linux syslog (text format) both generate authentication logs – normalization maps both to fields: timestamp, src_ip, username, action, result. Without normalization, a correlation rule would need separate logic for each log source. Common schemas: Common Information Model (CIM), Elastic Common Schema (ECS).

Q50 QUESTION

What is a SIEM correlation rule?

ANSWER

Correlation rules define logic to generate alerts from multiple events. Example rule: IF (failed_logins > 5 from same IP in 10 minutes) AND (then successful_login from same IP) AND (then access to sensitive_share) WITHIN 15 minutes □ ALERT: 'Probable credential brute force with successful access.' Correlation reduces alert fatigue by grouping related events into meaningful incidents.

Q51 QUESTION

What are SIEM use cases for detection?

ANSWER

Key SIEM detection use cases: (1) Brute force – multiple failed logins; (2) Impossible travel – login from New York then Beijing in 1 hour; (3) Privilege escalation – user gains admin rights outside change window; (4) Data exfiltration – large outbound transfer to new external IP; (5) Lateral movement – internal host scanning multiple IPs; (6) Malware C2 – beaconing to known bad IP; (7) Insider threat – access to data outside normal scope.

Q52 QUESTION

What is alert triage?

ANSWER

Alert triage determines whether an alert is a true positive, false positive, or requires escalation. Triage process: (1) Understand the alert — what rule fired, what data? (2) Gather context — who is the user, what is the asset? (3) Verify — check other logs, threat intel, UEBA; (4) Classify — True Positive, False Positive, Benign True Positive; (5) Act — escalate, contain, tune rule. Example: Alert 'port scan from 10.1.2.3' □ check change management □ it's a scheduled Nessus scan □ False Positive, tune rule to exclude scanner.

Q53 QUESTION

What is mean time to detect (MTTD) and mean time to respond (MTTR)?

ANSWER

MTTD: average time from when a breach occurs to when the SOC detects it. Industry average: 204 days (IBM 2023 Cost of Data Breach). MTTR: average time from detection to containment/resolution. Target: MTTD <4 hours for critical incidents; MTTR <24 hours for critical. Reducing MTTD/MTTR directly reduces breach cost — each day of reduced MTTD saves ~\$200K in breach costs.

Q54 QUESTION

What is log retention and why does it matter?

ANSWER

Log retention defines how long logs are kept for investigation and compliance. Requirements: PCI DSS — 12 months (3 months hot, 9 months cold); HIPAA — 6 years; GDPR — minimum needed for purpose. Security value: investigation timelines often extend weeks/months — need logs from before the attack. Example: A breach discovered today may have started 90 days ago (dwell time) — need 90+ days of logs to reconstruct the attack.

Q55 QUESTION

What is UEBA (User and Entity Behavior Analytics)?

ANSWER

UEBA uses ML to establish behavioral baselines and detect anomalies. Example: User 'jsmith' normally: logs in from Chicago at 8 AM, accesses 50 files/hour, never downloads more than 1 GB. UEBA detects: login from Vietnam at 3 AM, 5,000 files accessed in 30 minutes, 10 GB downloaded □ alert: 'Impossible travel + mass data access — possible account compromise or insider threat.' Catches threats signature-based detection misses.

Q56 QUESTION

What is NTA (Network Traffic Analysis)?

ANSWER

NTA analyzes network traffic patterns to detect threats. Tools: Zeek/Bro (protocol analysis, logs), Darktrace (AI-based anomaly detection), ExtraHop (protocol decoding), Corelight. Detections: C2 beaconing (periodic connections every 60 seconds), lateral movement (internal port scanning), DNS tunneling (long TXT queries), data exfiltration (large unexpected outbound transfers). NTA works on NetFlow, PCAP, or mirrored traffic.

Q57 QUESTION

What is a SOC playbook?

ANSWER

A SOC playbook is a documented, step-by-step response procedure for specific alert types. Example ransomware playbook: Step 1 – confirm alert (check process tree, file extension changes); Step 2 – immediate isolation (EDR quarantine or NAC block); Step 3 – collect memory image; Step 4 – notify CISO and legal; Step 5 – identify patient zero; Step 6 – assess backup integrity. Playbooks ensure consistent, auditable response and onboard new analysts faster.

Q58 QUESTION

What is false positive rate and how to reduce it?

ANSWER

False positive rate = FP alerts / total alerts. High FP rate causes alert fatigue – analysts stop investigating alerts. Reduction techniques: (1) Tune rules – add exceptions for known good behavior (scanner IPs, admin accounts); (2) Threshold adjustment – increase failed login count from 3 to 10 before alerting; (3) Context enrichment – add asset criticality, whitelist known-good software; (4) ML-based prioritization – score alerts by risk. Target: <20% FP rate.

Q59 QUESTION

What is a SIEM data source integration?

ANSWER

SIEM ingests logs via multiple methods: Syslog (Linux, network devices), WEF/WEC (Windows Event Forwarding to Windows Event Collector), API (cloud services – AWS CloudTrail, Azure AD), agents (Splunk UF, Elastic Agent, NXLog), JDBC/ODBC (databases), CEF/LEEF (security appliances). Example: Palo Alto firewall sends CEF-format syslog to Splunk; AWS CloudTrail delivers JSON logs to S3, fetched by Splunk via CloudWatch API.

Q60 QUESTION

What is threat detection maturity?

ANSWER

Detection maturity levels: Level 0 – no detection; Level 1 – basic perimeter alerts; Level 2 – SIEM with correlation rules; Level 3 – behavioral analytics, UEBA, NTA; Level 4 – active threat hunting, custom analytics. Example maturity assessment: Organization has SIEM with 50 correlation rules (Level 2) but no behavioral analytics or hunting program. Gap: implement UEBA and formalize hunting process to reach Level 3.

Q61 QUESTION

What is a security data lake?

ANSWER

A security data lake centralizes large volumes of raw security telemetry for long-term storage and advanced analytics. Example: All logs, NetFlow, PCAP metadata, endpoint telemetry stored in AWS S3 in Parquet format. Analysts query using Amazon Athena or Apache Spark. Advantage over SIEM: cheaper long-term storage, handles petabytes, supports ML workloads. SIEM for real-time alerting; data lake for historical hunting and ML training.

Q62 QUESTION

What is XDR (Extended Detection and Response)?

ANSWER

XDR integrates multiple security products (EDR, NDR, email security, cloud security) into a single detection and response platform. Example: Microsoft Defender XDR correlates: endpoint alert (suspicious PowerShell) + email alert (phishing email to same user) + identity alert (new admin account creation) = unified incident showing the full attack chain. Reduces investigation time by pre-correlating related alerts across domains.

Q63 QUESTION

What is EDR and its role in SOC?

ANSWER

EDR (Endpoint Detection and Response) provides continuous endpoint monitoring, threat detection, and response. SOC use cases: process injection detection, command-line logging (catch LOLBin abuse), file creation monitoring (ransomware detection), network connection logging, automated isolation. Example: CrowdStrike Falcon detects cmd.exe spawned by Word.exe (malicious macro) → alerts SOC with full process tree → analyst confirms and isolates endpoint with one click.

Q64 QUESTION

What is cloud-native SIEM?

ANSWER

Cloud-native SIEMs (Microsoft Sentinel, Chronicle, Elastic Cloud) offer elastic scaling, pay-per-use pricing, and native cloud integration. Example: Microsoft Sentinel ingests Azure AD, Microsoft 365, AWS, and GCP logs natively without complex connectors. Built-in ML analytics detect anomalies. Cost model: per-GB ingestion or per-workspace. Advantage: no hardware management, scales automatically for large log volumes.

Q65 QUESTION

What are SIEM performance metrics?

ANSWER

Key SIEM metrics: Events Per Second (EPS) ingestion capacity; log source coverage (% of assets sending logs); correlation rule count; alert volume (total, true positive, false positive); MTTD; MTTR; analyst queue depth; SLA compliance (% of alerts triaged within SLA). Dashboard example: 50,000 EPS ingested, 500 alerts/day, 20% TP rate, MTTD 4 hours, MTTR 2 hours. Review weekly to identify bottlenecks.

Q66 QUESTION

What is SOAR and how does it integrate with SIEM?

ANSWER

SOAR (Security Orchestration Automation Response) automates alert triage and incident response. Integration: SIEM generates alert → SOAR receives via API → SOAR playbook runs: (1) Enrich IP in VirusTotal, (2) Query Active Directory for user details, (3) Check CMDB for asset owner, (4) If confirmed malicious: isolate via EDR API, block IP in firewall API, create Jira ticket, notify Slack. All in seconds, without analyst intervention for tier-1 actions.

Q67 QUESTION

What is threat detection engineering?

ANSWER

Detection engineering is the discipline of creating, testing, and maintaining threat detections. Process: (1) Threat research – understand attacker technique; (2) Data assessment – which logs capture this technique?; (3) Rule design – define conditions that indicate the technique; (4) Testing – validate against real and simulated events; (5) Tuning – reduce false positives while maintaining true positive rate; (6) Deployment – push to SIEM/EDR; (7) Monitoring – measure FP rate and effectiveness; (8) Maintenance – update as attacker techniques evolve. Format: Sigma rules (vendor-neutral), KQL (Sentinel), SPL (Splunk), ES QL (Elastic). Document rationale for every rule.

Q68 QUESTION

What is log parsing and structured data?

ANSWER

Log parsing converts raw text logs into structured queryable fields. Example: Apache access log parsed into: src_ip, timestamp, http_method, uri, status_code, bytes_sent. SIEM tools use: Splunk TAs (Technology Add-ons) with pre-built regex extractions; Elastic Grok patterns; QRadar Log Source Extensions. Without proper parsing, correlation rules cannot match field values. Test: ingest 100 sample log lines and verify all fields extract correctly. Common mistake: assuming logs are already normalized — always verify field extraction before building detection rules on new log sources.

Q69 QUESTION

What is a use case library in a SOC?

ANSWER

A use case library catalogs all security detection use cases with metadata. Each entry includes: use case name, detection logic, data sources required, MITRE ATT&CK; technique mapping, expected true positive rate, known false positives and tuning actions, author and review date, severity and response playbook link. Benefits: prevents duplicate rule creation, enables gap analysis (which ATT&CK; techniques have no use case?), guides new analyst onboarding, documents institutional knowledge. Store in Git repository or wiki — version controlled and reviewed quarterly. Mature SOCs maintain 200+ use cases covering 60%+ of relevant ATT&CK; techniques.

4 Incident Response

21 Qs

Q70 QUESTION

What are the NIST incident response phases?

ANSWER

NIST SP 800-61r2 defines four phases: (1) Preparation — policies, playbooks, tools, team training, communication plans; (2) Detection and Analysis — identify incident, scope, classify severity; (3) Containment, Eradication, and Recovery — stop spread, remove malware, restore operations; (4) Post-Incident Activity — lessons learned, improve detection. SANS adds 'Identification' as a distinct phase between Detection and Containment.

Q71 QUESTION

What is incident classification and severity?

ANSWER

Incident classification by type: malware, data breach, DDoS, insider threat, phishing, unauthorized access. Severity levels: Critical (P1) — active breach of crown jewels, ransomware spreading; High (P2) — compromised privileged account, confirmed C2; Medium (P3) — phishing click, isolated malware; Low (P4) — policy violation, failed attack. Severity determines response speed (P1: 15-min response) and escalation path (P1: CISO + Legal + exec).

Q72 QUESTION

What is containment strategy?

ANSWER

Containment prevents spread while preserving evidence. Short-term: isolate affected systems (EDR quarantine, VLAN isolation, firewall rule). Long-term: business-impact-aware containment — can we take this system offline? Alternatives: shadow system, degraded mode. Evidence preservation: memory image, disk image before isolation. Example: Ransomware detected on fileserver □ immediately isolate from network, preserve memory image, identify scope before wiping and restoring.

Q73 QUESTION

What is eradication in incident response?

ANSWER

Eradication removes all attacker footholds. Checklist: remove malware (all instances across all systems), close initial access vector (patch CVE, disable compromised account), remove persistence mechanisms (scheduled tasks, registry run keys, startup items, webshells), reset ALL compromised credentials (including service accounts), audit for backdoors. Example: After ransomware — don't just decrypt; rebuild from clean images, rotate all AD credentials, patch the initial access vulnerability.

Q74 QUESTION

What is forensic preservation during IR?

ANSWER

Forensic preservation collects evidence without altering it. Order of volatility: CPU registers □ RAM □ network state □ running processes □ disk storage □ logs. Procedures: (1) Memory capture (WinPmem, LiME) before any other action; (2) Disk image with write blocker (FTK Imager, dd); (3) Network captures (Wireshark, tcpdump) from network tap; (4) Log preservation (copy to write-once storage); (5) Document everything with timestamps and hashes.

Q75 QUESTION

What is a cyber incident communication plan?

ANSWER

Communication plan defines who to notify, when, and how during an incident. Internal: SOC □ IR lead □ CISO □ Legal □ Executive team. External: regulators (GDPR 72h breach notification, SEC 4-day material incident disclosure), law enforcement (FBI IC3), cyber insurance provider, affected customers. Public relations plan for media. Example: Ransomware attack — CEO notified at P1; legal determines regulatory notification required; PR prepares statement; insurance carrier notified within 24h.

Q76 QUESTION

What is evidence handling and chain of custody?

ANSWER

Chain of custody documents every person who handles evidence. Required for legal proceedings. Steps: (1) Identify and label evidence (unique identifier); (2) Hash before and after collection (MD5 + SHA-256); (3) Photograph physical evidence; (4) Complete custody form (who, what, when, where); (5) Secure storage (evidence locker, encrypted drive); (6) Log every access. Break in chain = evidence inadmissible. Example: Forensic image hash must match at collection and analysis.

Q77 QUESTION

What is memory forensics and why is it critical?

ANSWER

Memory forensics analyzes RAM contents for evidence not on disk. Critical for: fileless malware (only in memory), encryption keys, network connections, running processes, credential material. Tools: Volatility 3 (open source), Magnet RAM Capture. Example: Volatility plugins — pslist (running processes), netscan (network connections), malfind (injected code), hashdump (cached credentials), cmdscan (command history). Evidence disappears on reboot — capture memory FIRST.

Q78 QUESTION

What is disk forensics?

ANSWER

Disk forensics recovers and analyzes data from storage devices. Key areas: (1) File system analysis — timeline of file creation/modification/access; (2) Deleted file recovery — files exist until sectors overwritten; (3) Artifact analysis — browser history, prefetch files, event logs, registry; (4) Partition analysis — hidden/encrypted partitions; (5) Slack space — data between end of file and end of cluster. Tools: Autopsy (open source), FTK, EnCase. Always work on forensic copy, never the original.

Q79 QUESTION

What is incident response tabletop exercise?

ANSWER

A tabletop exercise simulates an incident without live systems to test IR plans. Format: facilitator presents scenario inject-by-inject; participants discuss response actions. Example scenario: 'Alert fires — 50 endpoints showing ransomware activity. Finance director calls — can't access files. Customer portal is also down.' Discussion: containment decisions, communication chain, backup restore procedure, ransom payment policy. Output: identified gaps, updated playbooks, assigned action items.

Q80 QUESTION

What is the IR team structure?

ANSWER

IR team roles: Incident Commander (IC) — coordinates response, makes decisions; Technical Lead — directs forensics and containment; Forensics Analyst — collects and analyzes evidence; Threat Intelligence Analyst — provides attacker context; Communications Lead — internal/external notification; Legal Counsel — regulatory advice; CISO — executive oversight. External resources: IR retainer firm (Mandiant, CrowdStrike), cyber insurance breach coach, law enforcement liaison.

Q81 QUESTION

What is post-incident activity?

ANSWER

Post-incident activities occur within 2 weeks of closure. Components: (1) Timeline reconstruction — when did attacker enter, what did they do?; (2) Root cause analysis — what vulnerability/control failure allowed this?; (3) Lessons learned meeting — all involved teams; (4) Corrective action plan — specific improvements with owners and deadlines; (5) Report generation — executive summary + technical detail; (6) Update playbooks and detection rules based on incident TTPs.

Q82 QUESTION

What is an IR retainer?

ANSWER

An IR retainer is a pre-negotiated agreement with a specialized IR firm for emergency response services. Benefits: pre-agreed pricing, faster response (hours vs days for cold engagement), firm is pre-briefed on environment, insurance recognizes reputable retainer firms. Example: During a ransomware attack, call Mandiant (retainer) at 2 AM — they deploy incident handlers within 4 hours vs. 2-3 day negotiation without a retainer. Cost: \$20,000-\$100,000+/year retainer fee.

Q83 QUESTION

What is the legal and regulatory aspect of IR?

ANSWER

Legal considerations during IR: (1) Attorney-client privilege — route investigation through legal counsel to protect findings; (2) Breach notification laws — GDPR (72h), CCPA (within 45 days), HIPAA (60 days), SEC (4 business days for material incidents); (3) Law enforcement coordination — FBI can assist with attribution and decryption keys; (4) Evidence preservation for litigation — legal hold; (5) Contractual obligations — notify clients per contract terms.

Q84 QUESTION

What is IR metrics and reporting?

ANSWER

IR metrics for management: Number of incidents by severity/type; MTTD (mean time to detect); MTTR (mean time to respond/resolve); % incidents contained within SLA; Repeat incidents (same root cause); Cost per incident. Example dashboard: Q1 2024 — 847 incidents (2 Critical, 15 High, 350 Medium, 480 Low); MTTD 3.2 hours; MTTR 8.5 hours. Critical incidents trend: improving 30% YoY from investing in UEBA.

Q85 QUESTION

What is ransomware-specific IR?

ANSWER

Ransomware IR specifics: (1) Immediate isolation — every second the ransomware runs, more files encrypt; (2) Do NOT reboot — some ransomware wipes backups on next boot; (3) Identify variant — ransomlook.io, ID Ransomware — check for free decryptors on NoMoreRansom.org; (4) Shadow copy check — VSS still intact? (5) Backup integrity verification — are backups affected? Test restore; (6) Regulatory notification; (7) Law enforcement notification (FBI IC3); (8) Insurance notification; (9) Rebuild from clean images.

Q86 QUESTION

What is attack attribution?

ANSWER

Attack attribution identifies who conducted an attack. Technical attribution uses: malware code similarities, infrastructure overlap (IP, domains), TTPs matching known groups (MITRE ATT&CK; groups), language artifacts, operational security failures. Example: WannaCry attributed to Lazarus Group (North Korea) based on: code reuse from previous Lazarus malware, infrastructure overlap, unique code patterns. Attribution is difficult — adversaries use false flags. Focus on defense, not attribution.

Q87 QUESTION

What is incident scoping?

ANSWER

Incident scoping determines the full extent of compromise. Questions: Which systems are affected? What data was accessed/exfiltrated? When did the breach begin (dwell time)? What is the initial access vector? What persistence mechanisms exist? Scoping methods: EDR telemetry (lateral movement timeline), SIEM log analysis (authentication events), network logs (east-west traffic). Example: Initial alert on one workstation → scoping reveals 15 systems compromised over 45 days via stolen VPN credentials.

Q88 QUESTION

What is business continuity during IR?

ANSWER

Maintaining business operations during an incident while containing the threat. Considerations: Which systems can be isolated without stopping business? Failover to backup systems? Degraded mode operations? Communication channels if email is compromised (secure messaging app)? Example: Ransomware hits primary file server → failover to read-only backup share → finance continues critical functions → full restore within 4-hour RTO → business impact minimized.

Q89 QUESTION

What is threat actor dwell time?

ANSWER

Dwell time is the duration between initial compromise and detection. Global average: 16 days (Mandiant M-Trends 2024). APT groups may dwell for months/years. Longer dwell = more damage (data exfiltrated, lateral movement, implants planted). Reducing dwell time: threat hunting, UEBA (catches anomalies quickly), deception technology (attacker touches honeypot → immediate detection), network segmentation (limits lateral movement speed).

Q90 QUESTION

What is post-incident review facilitation?

ANSWER

Post-incident review (PIR) facilitation tips: (1) Hold within 5 business days while memories are fresh; (2) Blameless culture — focus on systems and processes, not individuals; (3) Structured agenda: timeline review, detection analysis, response analysis, prevention analysis, action items; (4) Include all involved teams — SOC, IT, legal, comms, affected business units; (5) Document all action items with SMART criteria — Specific, Measurable, Assignable, Realistic, Time-bound; (6) Track action item completion in next PIR; (7) Distribute written report within 2 weeks. Example action item: 'Implement MFA for VPN access (Owner: IT, Deadline: 30 days, Verification: Security scan confirms MFA required).'

5 Network Security Analysis

21 Qs

Q91 QUESTION

What is packet analysis and what tools are used?

ANSWER

Packet analysis captures and examines raw network traffic to identify attacks, anomalies, and evidence. Tools: Wireshark (GUI, ideal for interactive analysis), tcpdump (CLI, for capture), tshark (CLI version of Wireshark), Zeek/Bro (framework for protocol analysis and logging), Suricata (IDS/IPS with PCAP analysis). Example: Analyzing a PCAP in Wireshark with filter 'http contains password' to find cleartext credential submissions.

Q92 QUESTION

What is Wireshark and key display filters?

ANSWER

Wireshark is the industry-standard packet analyzer. Key filters: ip.addr==192.168.1.1 (traffic to/from IP); tcp.port==443 (HTTPS traffic); http.request.method==POST (form submissions); dns (all DNS traffic); tcp.flags.syn==1 && tcp.flags.ack==0 (SYN packets – port scan); follow TCP stream (reassemble conversation). Example: Investigating data exfiltration – filter for large outbound transfers: frame.len > 1000 && ip.dst != 10.0.0.0/8.

Q93 QUESTION

What is protocol analysis for threat detection?

ANSWER

Protocol analysis examines protocol behavior for anomalies. Examples: DNS – unusually long query names (DNS tunneling), high query rate to single domain (beaconing), non-standard query types (TXT records used for data exfiltration). HTTP – User-Agent strings matching known malware families, POST requests to unusual paths, encoded payloads. SMB – lateral movement (PsExec patterns), ransomware file writes across shares. Zeek logs protocol metadata for every connection.

Q94 QUESTION

What is NetFlow and how is it used for security?

ANSWER

NetFlow is a network protocol that captures metadata about network conversations (5-tuple: src IP, dst IP, src port, dst port, protocol) plus bytes, packets, duration. Unlike PCAP, no payload – privacy-friendly and efficient at scale. Example: NetFlow analysis detects: internal host 10.1.2.3 made 500 connections to unique IPs on port 445 in 10 minutes (SMB lateral movement/worm), or uploaded 500 GB to 198.x.x.x (data exfiltration). Tools: ntopng, Elastic, Splunk.

Q95 QUESTION

What is baseline network behavior?

ANSWER

Network baseline documents normal traffic patterns to identify anomalies. Baseline metrics: Top talkers (which hosts generate most traffic), protocol distribution (% HTTP vs HTTPS vs DNS), average bandwidth by hour/day, DNS query frequency per host, external connection patterns. Example: Baseline shows server X makes 100 DNS queries/hour. Alert when: server X makes 10,000 DNS queries/hour (DNS tunneling or C2 beaconing).

Q96 QUESTION

What is east-west vs north-south traffic analysis?

ANSWER

North-south: traffic between internal network and internet (perimeter). East-west: internal traffic between systems. Traditional security focused on north-south (perimeter firewall). Modern attacks use lateral movement (east-west). Example: APT gains initial access through phishing (north-south), then moves laterally across internal systems (east-west). East-west monitoring via: internal network taps, flow analysis, micro-segmentation logs.

Q97 QUESTION

What is a port scan and how to detect it?

ANSWER

Port scan sends connection attempts to multiple ports to identify open services. Types: SYN scan (half-open, stealthy), TCP connect scan (full handshake), UDP scan, version scan (-sV). Detection in SIEM: single IP attempting connections to many ports in short time. Zeek detects via: notice.log entries for port_scan policy. Example: Rule — if one IP attempts >100 unique destination ports in 60 seconds → alert.

Q98 QUESTION

What is DNS analysis for threat detection?

ANSWER

DNS is a rich source of threat intelligence. Detections: (1) DNS tunneling — base64-encoded subdomains, >50 character queries, high TXT query rate; (2) DGA (Domain Generation Algorithm) — high-entropy domain names (a8k3m2p.com vs google.com); (3) Newly registered domains — malware often uses fresh domains; (4) C2 beaconing — DNS queries to same domain every N seconds; (5) DNS rebinding attacks — resolves to internal IP from external domain.

Q99 QUESTION

What is SSL/TLS inspection and its challenges?

ANSWER

TLS inspection (SSL interception) decrypts HTTPS traffic for content inspection. Method: deploy a transparent proxy with a trusted enterprise CA certificate — proxy decrypts, inspects, re-encrypts. Security benefit: detect malware in HTTPS C2, DLP in encrypted channels. Challenges: (1) Certificate pinning — apps reject proxy certificate; (2) Privacy concerns — inspects all user HTTPS; (3) Performance overhead; (4) Breaks HPKP-pinned sites. Best practice: inspect, but log carefully and limit to corporate traffic only.

Q100 QUESTION

What is lateral movement detection?

ANSWER

Lateral movement is attacker progression through the network after initial compromise. Detection techniques: (1) Authentication anomalies — user authenticating to systems they've never accessed; (2) PsExec/remote execution patterns — admin tools used by non-admin accounts; (3) Pass-the-hash — NTLM authentication without corresponding Kerberos ticket; (4) SMB scanning — connection to port 445 across many internal IPs; (5) WMI remote execution — wmic.exe creating processes remotely.

Q101 QUESTION

What is beaconing detection?

ANSWER

Beaconing is malware checking in with C2 infrastructure at regular intervals. Detection: (1) Regular timing intervals – connection to same IP/domain every 60 seconds (beacon math: calculate jitter in connection timing); (2) Small consistent data sizes – 500 bytes outbound, 2KB inbound; (3) Long connection duration to single external IP; (4) Odd hours – beaconing at 3 AM when user isn't working. Tools: Rita (Real Intelligence Threat Analytics) specifically designed for beaconing detection.

Q102 QUESTION

What is exfiltration detection?

ANSWER

Data exfiltration detection: (1) Volume anomalies – host uploads 100x normal outbound data; (2) Uncommon protocols/ports – FTP/SFTP to unusual destinations, encrypted DNS, ICMP with large payloads; (3) DLP triggers – sensitive file patterns (PII, classified) detected in outbound traffic; (4) Destination analysis – transfer to personal cloud storage, Tor exit nodes, or known-bad IPs; (5) Timing – large transfers at off-hours when fewer eyes watching.

Q103 QUESTION

What is intrusion detection and prevention (IDS/IPS)?

ANSWER

IDS/IPS analyze traffic for known attack patterns. Detection methods: (1) Signature-based – matches known attack patterns (Snort rules); (2) Anomaly-based – detects deviations from baseline; (3) Stateful protocol analysis – validates protocol compliance. Placement: Network IDS (NIDS) on network tap (passive – detects, alerts); Inline IPS – actively blocks. Example: Snort rule 'alert tcp any any -> \$HOME_NET 80 (content:"../"; msg:"Directory Traversal");' fires on path traversal attempt.

Q104 QUESTION

What is PCAP analysis workflow?

ANSWER

PCAP analysis workflow: (1) Identify timeframe and relevant hosts; (2) Apply display filters to narrow scope; (3) Follow TCP/UDP streams for conversation context; (4) Export objects (HTTP files, SMB transfers, email attachments); (5) Analyze extracted files (hash check against VirusTotal); (6) Look for C2 patterns (beaconing, JA3 fingerprints); (7) Reconstruct timeline. Example: Extract malware payload from HTTP PCAP → upload to Any.run → identify C2 infrastructure.

Q105 QUESTION

What is a JA3 fingerprint?

ANSWER

JA3 is a method to fingerprint TLS clients based on the ClientHello message parameters (SSL version, cipher suites, extensions, elliptic curves). Same malware family has consistent JA3 hash regardless of IP or domain. Example: Cobalt Strike beacon has a distinctive JA3 fingerprint – detecting the JA3 hash in TLS logs catches C2 even if the C2 domain is new. Tools: Zeek generates JA3 hashes in ssl.log; threat intel feeds provide known-bad JA3 hashes.

Q106 QUESTION

What is network forensics vs live response?

ANSWER

Live response: collect evidence from running systems (volatile data – memory, connections, processes). Network forensics: analyze captured network traffic (PCAP, NetFlow, logs) for post-incident analysis. Both are complementary. Example: Live response captures memory (finds injected code), network forensics analyzes PCAP (reconstructs exfiltration timeline). Network forensics advantage: captures evidence the attacker tried to delete from the endpoint.

Q107 QUESTION

What is firewall log analysis?

ANSWER

Firewall logs show allowed/denied connections. Key fields: timestamp, src_ip, dst_ip, src_port, dst_port, protocol, action (allow/deny), bytes. Analysis use cases: (1) Denied traffic volume – spike may indicate scan or DDoS; (2) Allowed traffic to suspicious destinations – known-bad IPs; (3) Policy violations – internal traffic hitting unexpected external IPs; (4) Top-denied rules – identify which ports attackers probe most. Correlate with threat intel for IP reputation enrichment.

Q108 QUESTION

What is wireless network analysis?

ANSWER

Wireless analysis tools: Wireshark (capture 802.11 frames with monitor mode), aircrack-ng (capture handshakes, crack WPA2-Personal), Kismet (wireless IDS, rogue AP detection). Detection use cases: (1) Rogue APs – SSIDs not in authorized list, same SSID as corporate AP with different BSSID; (2) Deauth attacks – flood of 802.11 deauthentication frames; (3) Evil twin – AP with same SSID as corporate; (4) Wireless recon – probe requests revealing client device preferred networks.

Q109 QUESTION

What is honeypot and deception technology in network analysis?

ANSWER

Honeypots are decoy systems generating high-fidelity alerts. Network decoys: fake services on unused IP space (any connection = alert, no legitimate user should connect). Example: Deploy 10 fake systems across each network segment. Any internal host connecting to them = lateral movement indicator. Modern deception platforms (Attivo, Illusive Networks) deploy fake credentials, files, and network paths – attacker following breadcrumbs triggers immediate detection.

Q110 QUESTION

What is VPN log analysis?

ANSWER

VPN logs reveal remote access activity. Analysis: (1) Authentication failures – brute force attempts; (2) Impossible travel – VPN login from London 30 minutes after NY login; (3) Unusual hours – 3 AM VPN logins for an employee who works 9-5; (4) Long session duration – VPN session lasting 72 hours continuously (may be automated tool); (5) High data volume – employee downloads 50 GB over VPN in one session; (6) New device fingerprint – device never seen before.

Q111 QUESTION

What is network baseline documentation?

ANSWER

Network baseline documentation records normal traffic patterns for anomaly detection. Baseline components: (1) Top 10 talkers by volume (which hosts generate most traffic); (2) Protocol distribution (% breakdown by protocol – HTTP, HTTPS, DNS, SMB); (3) External connection patterns (which external IPs/domains does each host connect to normally?); (4) DNS query patterns (normal query frequency per host); (5) Bandwidth by hour/day (peak and average); (6) Port usage (which ports are normally used internally vs. externally). Update baseline quarterly and after major infrastructure changes. Deviations from baseline trigger investigation – not automatic blocking.

6 Endpoint Security Analysis

19 Qs

Q112 QUESTION

What is endpoint telemetry and what does it include?

ANSWER

Endpoint telemetry is continuous data collected from endpoints for security analysis. Includes: process creation (parent-child relationships, command-line arguments), file operations (creation, modification, deletion), registry changes, network connections, user logon/logoff events, loaded DLLs, scheduled task creation, service installation. Tools: EDR (CrowdStrike, SentinelOne, Microsoft Defender for Endpoint). Example: Word.exe spawning cmd.exe spawning PowerShell with encoded command = malicious macro indicator.

Q113 QUESTION

What is process tree analysis?

ANSWER

Process tree analysis examines parent-child process relationships to identify malicious execution. Normal: explorer.exe → Word.exe → winword.exe (legitimate). Malicious: winword.exe → cmd.exe → PowerShell.exe (malicious macro). Example indicators: Office app spawning PowerShell or cmd.exe; browser spawning cmd.exe; legitimate system processes (svchost, lsass) spawning unexpected children; processes running from temp directories; processes with misspelled names (svch0st.exe).

Q114 QUESTION

What are Windows event IDs critical for security?

ANSWER

Critical Windows Event IDs: 4624 (logon success), 4625 (logon failure), 4634 (logoff), 4648 (logon with explicit credentials), 4672 (special privileges assigned — admin logon), 4720 (user account created), 4728/4732 (user added to security group), 4776 (NTLM authentication), 4688 (process creation — enable auditing), 7045 (new service installed), 4698 (scheduled task created), 4663 (file access audit). Example: 4625 + 4624 + 4672 = brute force then successful admin logon.

Q115 QUESTION

What is LOLBin (Living off the Land Binaries) analysis?

ANSWER

LOLBins are legitimate Windows binaries abused for malicious purposes to evade detection. Common LOLBins: PowerShell (download and execute), certutil.exe (download files, decode base64), mshta.exe (execute HTA files with scripts), regsvr32 (execute DLLs without registration), rundll32 (execute DLLs), wscript/cscript (run VBScript/JScript), bitsadmin (background download). Detection: flag these processes with unusual parent processes, network connections, or command-line arguments.

Q116 QUESTION

What is fileless malware detection?

ANSWER

Fileless malware executes in memory without writing to disk. Detection methods: (1) Memory scanning — EDR with memory protection detects injected shellcode; (2) Script logging — PowerShell ScriptBlock logging (Event ID 4104) captures all executed PowerShell; (3) AMSI (Antimalware Scan Interface) — intercepts script execution before it reaches the interpreter; (4) ETW (Event Tracing for Windows) — kernel-level telemetry captures malicious actions; (5) Behavioral detection — flag encoded PowerShell execution, reflective DLL loading.

Q117 QUESTION

What is persistence mechanism analysis?

ANSWER

Attackers establish persistence to survive reboots. Common mechanisms: (1) Registry run keys (HKCU\Software\Microsoft\Windows\CurrentVersion\Run); (2) Scheduled tasks (check schtasks output for suspicious entries); (3) Services (new service installation — Event 7045); (4) Startup folder; (5) DLL hijacking; (6) WMI subscriptions; (7) Boot/pre-OS mechanisms (UEFI implants). Hunt: enumerate all persistence mechanisms on a system and compare to known-good baseline.

Q118 QUESTION

What is credential dumping detection?

ANSWER

Credential dumping extracts credentials from memory or registry. Methods: LSASS memory dumping (Mimikatz sekurlsa::logonpasswords), SAM registry dump, NTDS.dit extraction (domain credentials). Detection: (1) Event ID 4656 — handle to LSASS; (2) Process accessing lsass.exe (non-system process); (3) comsvcs.dll loaded by rundll32 (MiniDump technique); (4) reg.exe saving SAM/SYSTEM hive; (5) EDR alerts on credential dumping behavior. Mitigation: Credential Guard, PPL (Protected Process Light) for LSASS.

Q119 QUESTION

What is Windows Registry forensics?

ANSWER

Registry is a goldmine for forensic evidence. Key forensic artifacts: UserAssist (GUI program execution), ShimCache/AppCompatCache (program execution history), RecentDocs (recently opened files), RunMRU (recently run commands), TypedURLs (browser URLs), BAM/DAM (process execution with timestamps), Shellbags (folder access history), AutoRun keys (persistence). Tools: RegRipper, Registry Explorer. Example: ShimCache shows malware.exe executed at 3:47 AM even after file deletion.

Q120 QUESTION

What is prefetch file analysis?

ANSWER

Prefetch files (.pf) record application execution details on Windows. Location: C:\Windows\Prefetch\. Contains: executable name, execution count, last execution time (up to 8 timestamps in Windows 8+), files/directories accessed. Forensic value: proves a program ran even after deletion. Example: malware.exe-ABCDEF01.pf shows malware.exe ran at 2024-01-15 03:47:22 from C:\Users\victim\AppData\Local\Temp\ — five times total. Tools: PECmd (Eric Zimmerman), Autopsy.

Q121 QUESTION

What is event log analysis for IR?

ANSWER

Windows event log artifacts for incident investigation: Security log (authentication, privilege use), System log (service changes, driver loads), Application log (application errors), PowerShell logs (script execution), Sysmon log (process creation, network connections, file creation, registry changes). Sysmon Event IDs: 1 (process creation), 3 (network connection), 7 (DLL load), 11 (file creation), 13 (registry value set). Sysmon provides rich telemetry without EDR. Example: Sysmon Event 1 shows PowerShell downloading payload.

Q122 QUESTION

What is EDR telemetry analysis?

ANSWER

EDR platforms provide detailed endpoint telemetry for threat detection. CrowdStrike Falcon: process events, DNS requests, network connections, file writes, registry changes — all with parent process context. Microsoft Defender XDR: DeviceProcessEvents, DeviceNetworkEvents, DeviceFileEvents tables queryable with KQL. Example KQL query: DeviceProcessEvents | where InitiatingProcessFileName == 'winword.exe' and FileName == 'powershell.exe' — finds Word spawning PowerShell (malicious macro).

Q123 QUESTION

What is anti-forensics and how to detect it?

ANSWER

Anti-forensics attempts to hide attack evidence. Techniques: (1) Log clearing — wevtutil cl Security (Event ID 1102: Security log cleared); (2) Timestomping — modifying file timestamps (standard/mace times differ from \$STANDARD_INFORMATION vs \$FILE_NAME); (3) Secure delete — overwrite files before deletion; (4) Steganography — hide data in images; (5) Process injection — code in legitimate process. Detection: monitor for log clearing events, timestamp discrepancies in \$MFT, unusual processes.

Q124 QUESTION

What is malware sandbox analysis?

ANSWER

Malware sandboxes execute suspicious files in an isolated environment and record behavior. Tools: Any.run, Cuckoo (open source), Joe Sandbox, Tria.ge. Output: process tree, network connections (C2 domains/IPs), file drops, registry changes, API calls, screenshots. Example: Submit suspicious invoice.exe to Any.run □ it drops a DLL, injects into explorer.exe, connects to 185.234.x.x:443 □ analyst blocks the C2 IP and creates YARA rule for the dropped DLL.

Q125 QUESTION

What is YARA and how is it used?

ANSWER

YARA is a pattern-matching tool for identifying malware based on byte sequences, strings, or conditions. Example YARA rule for detecting Mimikatz: rule Mimikatz { strings: \$s1 = "mimikatz" nocase \$s2 = "sekurlsa" \$s3 = "lsadump" condition: 2 of them }. Runs against: memory images, disk images, file collections, email attachments. YARA rules shared via GitHub (YARA-Rules project), threat intel feeds, VirusTotal.

Q126 QUESTION

What is threat hunting on endpoints?

ANSWER

Endpoint hunting queries: (1) Suspicious process lineage — Word/Excel spawning PowerShell; (2) Encoded PowerShell — base64 -EncodedCommand flag; (3) Double file extension — invoice.pdf.exe; (4) Processes running from temp directories; (5) Unusual outbound connections from system processes (svchost.exe connecting to internet); (6) DLL loaded from user-writable location; (7) Scheduled tasks pointing to user temp directory. Tools: OSquery, Velociraptor, EDR hunting mode.

Q127 QUESTION

What is Sysmon and its key event IDs?

ANSWER

Sysmon (System Monitor) is a Windows service logging detailed system activity. Key event IDs: 1 (process create + command line), 2 (file creation time changed – timestamping), 3 (network connection), 5 (process terminated), 7 (image/DLL loaded), 8 (CreateRemoteThread – process injection), 10 (process accessed – LSASS access), 11 (file created), 12/13/14 (registry events), 15 (alternate data stream), 17/18 (named pipe), 22 (DNS query). SwiftOnSecurity and olaf-hartong Sysmon configs provide comprehensive coverage.

Q128 QUESTION

What is EDR alert investigation workflow?

ANSWER

EDR alert investigation: (1) Review the alert – what technique triggered? Process injection? Credential access?; (2) Examine process tree – what spawned the suspicious process? What did it spawn?; (3) Check command-line arguments – encoded PowerShell? Suspicious paths?; (4) Review network connections from the process – known bad IPs?; (5) Check file operations – files created/modified?; (6) Correlate with SIEM – other events from same host/user in same window?; (7) Classify – TP, FP, Benign TP; (8) If TP: escalate with full context summary; (9) If FP: document reason and tune rule to reduce noise.

Q129 QUESTION

What is endpoint hardening analysis?

ANSWER

Endpoint hardening assessment checks: (1) OS patch level – all critical patches applied?; (2) Antivirus/EDR present and updated?; (3) Local firewall enabled and configured?; (4) User account – is user a local admin? (should not be); (5) Auto-run entries – legitimate? (7) Services – unnecessary services running?; (8) Application control – AppLocker/WDAC configured?; (9) Credential Guard enabled (Windows)?; (10) Secure Boot enabled?; (11) Full disk encryption (BitLocker/FileVault) active?; (12) BIOS/UEFI password set?. CIS Benchmarks provide specific settings. Automated tools: CIS-CAT Pro, Nessus compliance scan, Microsoft Secure Score.

Q130 QUESTION

What is threat actor emulation on endpoints?

ANSWER

Endpoint threat actor emulation tests specific adversary behaviors against your defenses. Tools: Atomic Red Team (open-source test library mapped to ATT&CK;), CALDERA (automated adversary emulation), Invoke-Atomic (PowerShell). Example: Test T1059.001 (PowerShell execution): Invoke-AtomicTest T1059.001 □ executes encoded PowerShell □ check EDR alert and SIEM correlation rule both fire □ if either misses, investigate log gap or rule gap □ fix and retest. Run monthly on critical technique coverage. Results fed into detection gap analysis and rule improvement backlog.

7 Digital Forensics

16 Qs

Q131 QUESTION

What is the forensic investigation process?

ANSWER

Forensic investigation process: (1) Identification – recognize potential evidence; (2) Preservation – prevent alteration (write blockers, chain of custody); (3) Collection – acquire evidence (memory, disk, network); (4) Examination – apply forensic techniques; (5) Analysis – interpret findings, reconstruct events; (6) Reporting – document findings for technical and legal audiences; (7) Presentation – testify or brief stakeholders. Each step must be documented to maintain admissibility.

Q132 QUESTION

What is a forensic write blocker?

ANSWER

A write blocker prevents any writes to the evidence drive during acquisition. Hardware write blockers: Tableau, CRU Forensic TapeLock – connect between evidence drive and acquisition system. Software write blockers: Windows registry modification, Linux mount -o ro. Example: Connect suspect hard drive to Tableau T8-R2 write blocker → connect to forensic workstation → create forensic image with FTK Imager → write blocker ensures not a single byte is written to evidence drive.

Q133 QUESTION

What is file system forensics?

ANSWER

File system forensics analyzes file system structures for evidence. NTFS key structures: \$MFT (Master File Table – records all files), \$LogFile (transaction journal), \$USNJournal (change journal – file creation/deletion/rename history), \$I30 (directory index – records deleted files). FAT32: FAT table tracks clusters. Example: Even after deleting a file, \$MFT entry may persist, \$USNJournal records the deletion, directory slack may contain fragments – all recoverable with Autopsy.

Q134 QUESTION

What is timeline analysis in forensics?

ANSWER

Timeline analysis creates a chronological view of system activity from multiple artifacts. Sources: file system timestamps (\$MFT), Windows event logs, registry timestamps, browser history, prefetch files, Sysmon logs. Tools: Plaso (log2timeline), Timeline Explorer (Eric Zimmerman). Example: Timeline shows: 14:00 – phishing email received; 14:23 – malicious attachment opened; 14:24 – PowerShell process created; 14:25 – network connection to C2; 14:30 – credential dumping; 14:45 – lateral movement began.

Q135 QUESTION

What is mobile device forensics?

ANSWER

Mobile forensics recovers data from smartphones and tablets. Tools: Cellebrite UFED, MSAB XRY, Magnet AXIOM. Data sources: call records, SMS/iMessage, WhatsApp/Telegram, photos (EXIF data with GPS), browser history, app data, location history, cloud backup artifacts. Challenges: full disk encryption (without PIN = data unreadable), biometric bypass, cloud data (requires warrant), app-level encryption (Signal). Legal: requires search warrant in most jurisdictions.

Q136 QUESTION

What is cloud forensics?

ANSWER

Cloud forensics collects evidence from cloud environments. Challenges: shared responsibility (logs controlled by provider), jurisdictional issues (data in multiple countries), ephemeral resources (containers/serverless spin up and down), log availability varies by service tier. Evidence sources: cloud provider audit logs (AWS CloudTrail, Azure Activity Log), storage access logs (S3 access logs), IAM history, network flow logs (VPC Flow Logs). Preservation: snapshot instances, preserve logs before they expire.

Q137 QUESTION

What is artifact analysis for common browser forensics?

ANSWER

Browser forensic artifacts: History (visited URLs, visit count, timestamp), Cookies (session tokens, user preferences), Cache (downloaded content, images), Download history, Form data (saved passwords), Favicons (icon for visited sites), SessionStorage/localStorage (web app data). Location: Chrome — C:\Users\%user%\AppData\Local\Google\Chrome\User Data\Default\. Tools: Hindsight (Chrome forensics), Autopsy browser artifact plugin, BrowsingHistoryView. Even private/incognito mode leaves some artifacts.

Q138 QUESTION

What is volatile data collection?

ANSWER

Volatile data disappears when system powers off. Collection order (most to least volatile): (1) CPU registers and cache (theoretical only); (2) Running processes — tasklist, Get-Process; (3) Network connections — netstat -an; (4) Open files — handle.exe, lsof; (5) Logged-on users — query user; (6) RAM — WinPmem, LiME (Linux); (7) System time and uptime; (8) Clipboard contents. Tools: KAPE (Kroll Artifact Parser), Velociraptor, FRF (Fast Response Framework).

Q139 QUESTION

What is log analysis in digital forensics?

ANSWER

Forensic log analysis reconstructs events from system logs. Windows: Security log (4624, 4625, 4720), System log (7045 — new service), Application, PowerShell, Sysmon. Linux: /var/log/auth.log (authentication), /var/log/syslog (system events), /var/log/apache2/access.log (web server), bash history (~/.bash_history). Challenges: logs may be cleared (Event ID 1102), manipulated, or simply absent. Correlate multiple sources for redundancy.

Q140 QUESTION

What is steganography detection in forensics?

ANSWER

Steganography hides data inside other data (images, audio, video). Detection: (1) Statistical analysis — steganalysis tools detect anomalies in pixel distribution (stegdetect, StegExpose); (2) File size anomalies — JPEG much larger than expected for resolution; (3) Metadata analysis — creation tool, authoring software; (4) Bit-level analysis — LSB patterns in images. Example: Suspect image shows chi-square test failure indicating LSB steganography — extract hidden data with steghide.

Q141 QUESTION

What is registry forensics for persistence?

ANSWER

Registry persistence keys: HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run (runs at startup for all users), HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run (per-user), HKLM\SYSTEM\CurrentControlSet\Services (services), HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon\Userinit (logon script). Tool: RegRipper automates extraction of forensic artifacts from registry hives. Example: Run key contains: 'C:\Users\victim\AppData\Local\Temp\svchost.exe -k netsvcs' — malware masquerading as svchost.

Q142 QUESTION

What is artifact correlation in forensics?

ANSWER

Artifact correlation connects evidence from multiple sources to reconstruct events. Example: Email forensics shows phishing at 14:00 □ Sysmon log shows Word.exe spawning PowerShell at 14:23 □ Memory forensics shows injected shellcode in explorer.exe at 14:25 □ Network forensics shows connection to 185.234.x.x at 14:26 □ File system shows new DLL in AppData at 14:27 □ Event log shows new scheduled task at 14:30. Full attack chain reconstructed from 6 sources.

Q143 QUESTION

What is forensic reporting?

ANSWER

Forensic reports document findings for legal and technical audiences. Components: (1) Executive Summary — non-technical overview, key findings, business impact; (2) Technical Analysis — detailed findings with evidence references; (3) Timeline — chronological attack reconstruction; (4) Evidence inventory — all collected evidence with hashes; (5) Methodology — tools and techniques used; (6) Findings and conclusions — what happened, how, who; (7) Recommendations — corrective actions. Reports must be factual, objective, reproducible.

Q144 QUESTION

What is artifact analysis with Autopsy?

ANSWER

Autopsy is an open-source digital forensics platform with a GUI frontend for The Sleuth Kit. Features: timeline analysis, keyword search, hash lookup (NSRL database), web artifact extraction, email parsing, mobile device support, extensible via Python/Java modules. Workflow: add disk image □ run ingest modules □ review flagged items □ tag evidence □ generate HTML/Excel report. Example: Autopsy keyword search finds 'bitcoin' in unallocated disk space, linking suspect to ransomware payment. Free alternative to commercial tools like FTK and EnCase for basic investigations.

Q145 QUESTION

What is deleted file recovery?

ANSWER

Deleted file recovery is possible because most OS operations only remove directory entries and mark clusters as available without immediately overwriting data. File carving searches for file headers and footers (PDF: %PDF-, JPEG: FFD8FF, ZIP: 504B0304) in unallocated space. Tools: Autopsy, Recuva, PhotoRec, Foremost. Example: Suspect deletes invoice.pdf □ Autopsy carves full file from unallocated space □ SHA-256 hash matches known ransomware receipt. SSDs with TRIM enabled complicate recovery — data may be erased immediately after deletion.

Q146 QUESTION

What is network forensics artifacts?

ANSWER

Network forensic evidence sources: full PCAP files, NetFlow/IPFIX records (session metadata without payload), firewall logs (connection allowed/denied with timestamps), proxy logs (URL, user, bytes), DNS server logs (query/response pairs with client IP), IDS/IPS alerts with packet context, SSL/TLS handshake logs with JA3 fingerprints. Example reconstruction: proxy logs show user accessed malicious URL at 14:00 □ DNS log shows C2 domain resolved at 14:01 □ firewall shows outbound connection established □ PCAP shows data transferred. Four sources confirm the exfiltration timeline.

8 Cloud Security Analysis

14 Qs

Q147 QUESTION

What is cloud security monitoring?

ANSWER

Cloud security monitoring collects and analyzes telemetry from cloud services. AWS: CloudTrail (API calls), CloudWatch (metrics, logs), GuardDuty (threat detection), Security Hub (aggregated findings), VPC Flow Logs (network traffic), Config (configuration changes). Azure: Azure Monitor, Defender for Cloud, Azure AD Sign-in logs, Activity Log. GCP: Cloud Audit Logs, Security Command Center. Example: CloudTrail log shows root account login from unusual IP → GuardDuty alert → immediate investigation.

Q148 QUESTION

What is AWS CloudTrail analysis?

ANSWER

CloudTrail records all AWS API calls: who (userAgent, principalId), what (eventName), when (eventTime), where (sourceIPAddress), which resource (requestParameters). Key events to monitor: ConsoleLogin (especially for root), CreateAccessKey, AttachUserPolicy (privilege escalation), DeleteTrail (covering tracks), RunInstances (unexpected EC2 launch), GetSecretValue (secret access), PutBucketPolicy (S3 permission change). Example alert: DeleteTrail from non-admin account = attacker trying to cover tracks.

Q149 QUESTION

What is cloud IAM analysis for threat detection?

ANSWER

IAM analysis detects privilege escalation and unauthorized access. Key indicators: (1) Unused roles suddenly used; (2) Access key used from new geographic location; (3) New IAM user created (esp. with admin rights); (4) Policy attached to user directly (should use roles); (5) SCP (Service Control Policy) modified; (6) AssumeRole to cross-account; (7) Root account used (should be MFA-protected, rarely used). Example: CloudTrail shows CreateUser + AttachUserPolicy AdministratorAccess at 3 AM = likely compromised account.

Q150 QUESTION

What is container security analysis?

ANSWER

Container security monitoring: (1) Image scanning — CVEs in base images (Trivy, Anchore); (2) Runtime security — detect container escape, privileged container execution (Falco); (3) Kubernetes audit logs — who did what in K8s; (4) Network policy analysis — verify containers only communicate as intended; (5) Secret scanning — credentials in container environment variables. Example: Falco alert 'A shell was spawned in a container' → attacker gained shell in running container → alert triggers IR workflow.

Q151 QUESTION

What is a cloud security misconfiguration?

ANSWER

Common cloud misconfigurations: (1) Public S3 bucket exposing sensitive data; (2) Security group 0.0.0.0/0 on port 22/3389 (SSH/RDP internet-exposed); (3) No MFA on root account; (4) CloudTrail disabled or single-region only; (5) Public RDS database; (6) Lambda with overly permissive IAM role; (7) Unencrypted EBS volume containing sensitive data. Detection tools: AWS Security Hub, Prisma Cloud, Checkov for IaC scanning.

Q152 QUESTION

What is CSPM and its role in cloud analysis?

ANSWER

CSPM (Cloud Security Posture Management) continuously monitors cloud environments for misconfigurations and compliance violations. Functions: discover all cloud resources (agentless), check against CIS benchmarks, identify publicly exposed resources, detect compliance drift, provide remediation guidance. Example: Prisma Cloud detects an S3 bucket created by a developer as public – auto-remediates by disabling public access and creates a ticket for the developer. Integrates with CI/CD to prevent misconfigs before deployment.

Q153 QUESTION

What is GuardDuty and its detection capabilities?

ANSWER

AWS GuardDuty is a managed threat detection service using ML, anomaly detection, and threat intelligence. Detection categories: Unauthorized Access (root credential use, API calls from unusual geos), Backdoor (EC2 instances contacting known C2 IPs), Crypto Mining (EC2 running miners), Recon (port scanning, failed auth), Trojan (EC2 calling known botnet C2). Example: GuardDuty finding: UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration. InsideAWS – EC2 credentials used outside the instance (stolen from IMDS).

Q154 QUESTION

What is cloud incident response?

ANSWER

Cloud IR differs from traditional IR: (1) No physical access – all via APIs; (2) Ephemeral resources – instances may terminate automatically; (3) Shared responsibility – provider manages some IR aspects; (4) Log preservation – CloudTrail logs expire, must archive; (5) Isolation – restrict security group (block all inbound/outbound) vs. terminate (loses volatile data). Cloud IR workflow: identify compromised resources □ snapshot disk □ restrict network access □ preserve logs □ analyze □ eradicate □ recover.

Q155 QUESTION

What is SaaS security analysis?

ANSWER

SaaS security monitoring via CASB and native logging. Key events: failed logins, impossible travel, mass downloads, sharing sensitive files externally, new OAuth app granted permissions. Example: Microsoft 365 Unified Audit Log shows user 'jdoe' downloaded 10,000 files in 2 hours (normal: 50/hour) □ CASB alert □ investigation reveals account compromise. Third-party OAuth apps granted excessive permissions are a common attack vector – audit regularly.

Q156 QUESTION

What is cloud network security analysis?

ANSWER

AWS network security analysis: VPC Flow Logs record connection metadata (src/dst IP, port, protocol, bytes, action). Analysis: identify traffic to known-bad IPs, detect port scanning patterns, find unexpected cross-VPC communication, spot data exfiltration volumes. Example: VPC Flow Log query: SELECT sourceaddress, destinationaddress, bytes WHERE destinationaddress NOT IN (known_good_IPs) AND bytes > 1000000 □ finds large transfers to unknown external IPs.

Q157 QUESTION

What is multi-cloud security analysis?

ANSWER

Multi-cloud environments (AWS + Azure + GCP) create visibility gaps. Challenges: different log formats, different native security tools, different IAM models. Solutions: cloud-agnostic SIEM (Microsoft Sentinel, Chronicle) ingesting all providers; CSPM with multi-cloud support (Wiz, Orca, Prisma Cloud); Unified identity platform (Okta + SSO across all clouds). Example: Chronicle SIEM ingests AWS CloudTrail + Azure Activity Log + GCP Cloud Audit Logs → unified detection across all clouds.

Q158 QUESTION

What is AWS security log centralization?

ANSWER

AWS security log centralization strategy: (1) Enable CloudTrail in all regions with multi-region trail → S3 bucket in security account with Object Lock (immutable for N days); (2) VPC Flow Logs → CloudWatch Logs → S3 → SIEM; (3) GuardDuty in all regions → Security Hub → SIEM via EventBridge; (4) Config → delivery to S3 → SIEM for configuration change tracking; (5) S3 access logs for sensitive buckets. Use cross-account S3 bucket policy so member accounts can write logs but only security account can read/delete. Prevents attackers from deleting logs even if they compromise the target account.

Q159 QUESTION

What is Kubernetes security monitoring?

ANSWER

Kubernetes threat detection with Falco: Falco monitors syscalls in real-time using eBPF or kernel module. Example rules: 'A shell was run in a container' (T1609), 'Sensitive file accessed in container' (/etc/shadow, /etc/kubernetes/admin.conf), 'Container running with dangerous capabilities' (CAP_SYS_ADMIN), 'Unexpected network connection from container'. Falco outputs alerts to stdout, Slack, SIEM, or Falcosidekick (multi-output aggregator). Kubernetes API audit logs capture all kubectl commands — enable and send to SIEM for centralized analysis.

Q160 QUESTION

What is cloud threat hunting?

ANSWER

Cloud threat hunting queries: (1) Unused IAM roles suddenly active (CloudTrail: AssumeRole for roles with LastUsedDate > 90 days ago); (2) Root account usage (CloudTrail: filter where userIdentity.type = Root); (3) S3 bucket policy changes (CloudTrail: PutBucketPolicy events); (4) New IAM user with admin policy (CreateUser + AttachUserPolicy AdministratorAccess same day); (5) EC2 instances making unusual API calls for their role (instance metadata abuse); (6) CloudTrail disabled (DeleteTrail, StopLogging — attacker covering tracks). Athena queries on CloudTrail S3 data enable ad-hoc hunting.

9 Identity & Access Analysis

14 Qs

Q161 QUESTION

What is Active Directory security analysis?

ANSWER

AD security analysis monitors for attacks targeting the directory. Key events: 4720 (account created), 4728 (user added to Domain Admins), 4769 (Kerberos service ticket – Kerberoasting), 4771 (Kerberos pre-auth failed – AS-REP Roasting), 4776 (NTLM auth), 4624/4625 (logon success/failure). Threat-specific monitoring: BloodHound for attack path analysis, Defender for Identity (on-premises AD threat detection), PingCastle for AD security assessment.

Q162 QUESTION

What is Kerberoasting detection?

ANSWER

Kerberoasting requests service tickets (TGS) for service accounts to crack their passwords offline. Detection: Event ID 4769 (Kerberos service ticket request) with RC4 encryption type (0x17) for service accounts with SPNs – legitimate requests typically use AES (0x12/0x18). Alert: multiple 4769 events with etype 0x17 from the same source in a short period. Prevention: use strong service account passwords (25+ random chars), use gMSA (Group Managed Service Accounts), audit SPN assignments.

Q163 QUESTION

What is pass-the-hash detection?

ANSWER

Pass-the-hash uses an NTLM hash to authenticate without the plaintext password. Detection: Event ID 4624 with Logon Type 3 (network logon) using NTLM (rather than Kerberos) authentication from an unexpected source. Indicator: NTLM authentication to domain-joined systems (should use Kerberos in a healthy domain). Monitoring: alert on NTLM authentication in Kerberos-enabled environments. Prevention: Credential Guard, network-level controls blocking lateral NTLM.

Q164 QUESTION

What is DCSync attack detection?

ANSWER

DCSync mimics a Domain Controller to request password hashes for any user via MS-DRSR (Directory Replication Service Remote Protocol). Detection: Event ID 4662 with access rights 0x100 (Control Access) on the domain object for accounts that are NOT Domain Controllers. Mimikatz command: `lsadump::dcsync /domain:corp.com /user:krbtgt`. Prevention: restrict DS-Replication-Get-Changes permissions to only DCs, monitor 4662 events.

Q165 QUESTION

What is an identity-based threat analysis?

ANSWER

Identity threat analysis examines user account behavior for anomalies. Indicators: (1) Account accessing resources it never has before; (2) Authentication from new geolocation or device; (3) Service account making interactive logons; (4) Multiple failed logins then success (brute force); (5) Account used during unusual hours; (6) Privilege use outside working hours; (7) Stale accounts suddenly active. Tools: Microsoft Defender for Identity, Okta ThreatInsight, Azure AD Identity Protection.

Q166 QUESTION

What is MFA bypass technique detection?

ANSWER

MFA bypass methods: (1) MFA fatigue/push bombing – flood user with MFA push requests until they approve; (2) SIM swapping – hijack phone number to receive SMS OTP; (3) SS7 attacks – intercept SMS; (4) Adversary-in-the-middle (EvilGinx, Modlishka) – real-time proxy captures session cookies after MFA. Detection: unusual MFA request volume (30+ push notifications in 5 minutes), session token used from new IP immediately after MFA, phone number changes in identity provider logs.

Q167 QUESTION

What is privileged account monitoring?

ANSWER

Privileged account monitoring focuses on admin, service, and shared accounts. Key monitoring: (1) Admin account logons – where, when, from what system; (2) Service account interactive logons (should be non-interactive); (3) Admin actions outside change windows; (4) Bulk operations (mass account creation, policy changes); (5) PAM checkout logs – who used which admin credential when. Example: Alert if Domain Admin account logs in from a workstation (should only log in from PAW – Privileged Access Workstation).

Q168 QUESTION

What is lateral movement via stolen credentials?

ANSWER

Credential theft enabling lateral movement: (1) Mimikatz dumps LSASS – extracts NTLM hashes/Kerberos tickets; (2) Attacker uses pass-the-hash/pass-the-ticket to authenticate to other systems; (3) Key detection events: 4624 Type 3 NTLM from compromised host to new targets; (4) Unusual admin connections between workstations (workstations should not admin other workstations); (5) WMI/PsExec connections from unexpected sources. Zeek SMB and authentication logs show this pattern.

Q169 QUESTION

What is Azure AD / Entra ID threat detection?

ANSWER

Azure AD (now Entra ID) attack detections: (1) Impossible travel – signin from two countries within 1 hour; (2) Anonymous IP (Tor exit node); (3) Unfamiliar sign-in properties (new device, browser, location); (4) Leaked credentials (Microsoft checks dark web); (5) Password spray – multiple account failures same IP; (6) Suspicious inbox rule (auto-forward to external email – BEC indicator); (7) Service principal added to admin role. Azure AD Identity Protection generates risk signals feeding Conditional Access.

Q170 QUESTION

What is service account analysis?

ANSWER

Service accounts (non-human identities) require special monitoring: (1) They often have excessive privileges (old admins granted admin rights); (2) Passwords rarely rotated (legacy – break-fix concern); (3) Interactive logons are suspicious (service accounts shouldn't log on interactively); (4) Usage outside expected systems (SQL service account suddenly authenticating to HR server). Detection: Event 4624 Type 2 (interactive) for service accounts; Logon from unexpected source hosts; New SPN assignments.

Q171 QUESTION

What is OAuth attack analysis?

ANSWER

OAuth attacks exploit application authorization. Common attacks: (1) Malicious OAuth app — user grants permission to attacker's app that reads all email; (2) Token theft — steal access/refresh tokens to maintain persistence; (3) Consent phishing — fake Microsoft 365 permissions page to grant attacker access. Detection: Audit OAuth apps with excessive permissions, monitor for new app registrations with sensitive scopes (Mail.Read, Files.ReadWrite.All), detect token use from unusual IPs after initial OAuth grant.

Q172 QUESTION

What is BloodHound and AD attack path analysis?

ANSWER

BloodHound maps Active Directory attack paths using graph theory. SharpHound collector queries AD for: users, groups, computers, GPOs, ACLs, session data, local admin rights. BloodHound Neo4j database stores relationships, GUI visualizes attack paths. Example: BloodHound query 'Shortest path from Domain Users to Domain Admins' reveals: any domain user can reset HelpDesk account password (ACL) □ HelpDesk is local admin on WORKSTATION-042 □ WORKSTATION-042 has Domain Admin session (ticket in memory). Blue team uses BloodHound to find and break dangerous paths before attackers exploit them.

Q173 QUESTION

What is Kerberos ticket analysis?

ANSWER

Kerberos ticket analysis for threat detection: (1) Pass-the-Ticket — Kerberos ticket used from different IP than where it was issued; (2) Golden Ticket — TGT with domain SID, krbtgt hash — forged to any user with any lifetime; (3) Silver Ticket — service ticket forged with service account hash — no KDC contact needed; (4) Overpass-the-Hash — NTLM hash converted to Kerberos ticket. Detection: Event 4769 (service ticket request) with unusual encryption types, impossible ticket lifetimes, or requests for services the account never accesses. Microsoft Defender for Identity specializes in Kerberos attack detection.

Q174 QUESTION

What is PAM (Privileged Access Management) analysis?

ANSWER

PAM provides controls for privileged accounts. Security analysis use cases: (1) Vault checkout audit — who checked out which admin credential and when?; (2) Privileged session recording — full keystrokes and screen capture of admin sessions; (3) Password rotation verification — all admin passwords rotated after use?; (4) JIT access review — temporary admin grants were properly revoked?; (5) Unusual access patterns — admin account checked out at unusual time/from unusual location. Example: PAM log shows 'root password checked out by jdope at 3 AM from VPN' when jdope is on vacation □ immediate investigation triggered.

10 Malware Analysis

15 Qs

Q175 QUESTION

What is static malware analysis?

ANSWER

Static analysis examines malware without executing it. Steps: (1) File type identification — file command, magic bytes, trid; (2) Hashing — MD5/SHA-256 for VirusTotal lookup; (3) String extraction — strings.exe reveals URLs, IP addresses, registry keys, error messages; (4) Import analysis — what Windows APIs does it use? (CreateRemoteThread = injection, InternetOpenUrl = network); (5) Packing detection — PEiD, DIE; (6) Header analysis — PEStudio for PE headers, sections, timestamps.

Q176 QUESTION

What is dynamic malware analysis?

ANSWER

Dynamic analysis executes malware in a controlled environment to observe behavior. Methods: (1) Automated sandbox — Any.run, Cuckoo, Joe Sandbox; (2) Manual analysis — run in isolated VM, monitor with Process Monitor, Wireshark, Regshot. Observables: files dropped, registry keys created, network connections, processes spawned, mutexes created, API calls. Example: Malware drops svchost.exe in AppData, creates Run key, connects to 185.x.x.x:443 every 60 seconds — behavior profile created.

Q177 QUESTION

What is malware classification?

ANSWER

Malware classification by behavior: Ransomware (encrypts files), RAT/Remote Access Trojan (remote control), Stealer (credential/browser data theft), Dropper (downloads/install other malware), Loader (loads additional payloads in memory), Rootkit (hides itself), Bootkit (persists in boot sector), Wiper (destroys data), Cryptominer (steals compute resources), Spyware (keylogging, screen capture), Botnet (DDoS, spam). Modern malware is multi-functional — combines stealer + dropper + RAT capabilities.

Q178 QUESTION

What is a malware indicator extraction?

ANSWER

Indicators extracted from malware analysis: Network IoCs (C2 IPs, domains, URLs, JA3 fingerprints, HTTP headers), File IoCs (hashes — MD5/SHA-256/SHA-1, file names, file paths, mutexes, PE timestamp), Registry IoCs (persistence keys, configuration storage), Behavioral IoCs (process injection, LOLBin usage, unusual API call sequences). Example: Analyzing Emotet DLL extracts: C2 IPs list, encrypted config location, mutex name, dropped file path — all become detection indicators.

Q179 QUESTION

What is code similarity analysis?

ANSWER

Code similarity identifies malware families and variants through shared code. Tools: BinDiff (binary function comparison), SSDEEP (fuzzy hashing — finds similar files not exact matches), TLSH, YARA (pattern matching on shared strings/byte sequences). Example: New malware sample shares 70% code similarity with known Ryuk ransomware variant via BinDiff → classify as Ryuk variant → apply existing detection rules and response playbook.

Q180 QUESTION

What is a RAT (Remote Access Trojan) analysis?

ANSWER

RAT provides remote control: keylogging, screen capture, webcam access, file upload/download, command execution, lateral movement. Analysis focus: C2 communication protocol (custom binary, HTTP, DNS), persistence mechanism, encryption used. Example: njRAT analysis reveals: (1) Persistence via Run key; (2) C2 over TCP to dynamic DNS domain; (3) Configuration stored in registry (base64 encoded); (4) Features: keylogger, screen capture, webcam, remote shell. IoCs extracted and distributed.

Q181 QUESTION

What is ransomware analysis?

ANSWER

Ransomware analysis workflow: (1) Safe execution in isolated VM (NO network connection); (2) Pre-infection snapshot → execute → post-infection snapshot → compare (Regshot); (3) Monitor file operations (Process Monitor) – what files were encrypted?; (4) Analyze encryption (AES? RSA? What key material?); (5) Check for shadow copy deletion (vssadmin delete shadows); (6) Extract ransom note text and payment address; (7) Submit to NoMoreRansom.org for known decryptor; (8) Identify family via ID Ransomware.

Q182 QUESTION

What is command-and-control (C2) analysis?

ANSWER

C2 analysis identifies attacker infrastructure for detection and hunting. Extraction methods: (1) Dynamic analysis – monitor network connections during execution; (2) Configuration extraction – many RATs store C2 in encrypted config; (3) String analysis – hardcoded C2 URLs or IPs; (4) Protocol analysis – custom C2 protocol in Wireshark/PCAP. Resulting IoCs: C2 IPs/domains, URL paths, HTTP headers, User-Agent strings, beacon interval, encryption keys. Feed to threat intel platform for organization-wide blocking.

Q183 QUESTION

What is malware persistence mechanism analysis?

ANSWER

Persistence mechanisms keep malware running after reboot. Analysis targets: Registry run keys (RegShot before/after), Scheduled tasks (schtasks /query), Services (sc query), Startup folder, WMI subscriptions (Get-WMIObject -Namespace root\subscription), Boot sector modification (not visible to running OS – boot offline media to detect). Example: Process Monitor captures malware writing to HKCU\Run key during execution → persistence mechanism documented and becomes detection indicator.

Q184 QUESTION

What is obfuscation and deobfuscation?

ANSWER

Malware obfuscates code to evade analysis and detection. Techniques: (1) Packing – compress and encrypt executable (UPX, custom); (2) Encoding – base64, hex, ROT13 in scripts; (3) Encryption – XOR, AES with embedded key; (4) Code virtualization – custom VM executes bytecode (VMProtect, Themida). Deobfuscation: manual analysis (IDA Pro, Ghidra), dynamic approach (let malware deobfuscate itself then dump memory), specialized tools (CyberChef for scripting deobfuscation).

Q185 QUESTION

What is threat actor attribution through malware analysis?

ANSWER

Malware analysis provides attribution evidence: (1) Code reuse – functions shared with known actor's previous malware; (2) Compile artifacts – PDB paths reveal development environment details; (3) Language artifacts – strings in non-English language; (4) Operational security failures – attacker infrastructure reuse; (5) Toolmark analysis – unique coding style or library usage. Example: PyXie RAT attributed to TrickBot group based on shared decryption routines and infrastructure overlap.

Q186 QUESTION

What is YARA rule writing for malware detection?

ANSWER

YARA rules define patterns to identify malware families. Components: meta (description, author, date), strings (text strings, hex patterns, regex), condition (logic combining strings). Example rule: rule Ryuk_Ransomware { meta: author = "TechShiksha" strings: \$s1 = "RyukReadMe" nocase \$s2 = { 45 4E 43 52 59 50 54 45 44 } (hex pattern) \$note = "Your personal files are encrypted" condition: (\$s1 or \$s2) and \$note and uint16(0) == 0x5A4D }. Test with: yara -r ryuk.yar /suspicious/.

Q187 QUESTION

What is behavioral indicators of compromise (BloC)?

ANSWER

Behavioral IoCs describe malicious patterns rather than specific artifacts. Examples: (1) Office application spawning cmd.exe or PowerShell (malicious macro indicator); (2) Process writing to startup location (persistence); (3) LSASS memory access by non-system process (credential dumping); (4) Mass file rename with new extension (ransomware); (5) Internal port scan from workstation (lateral movement); (6) Large outbound transfer to new destination (exfiltration). BloCs are durable – attackers change IPs and hashes daily but rarely change core techniques. EDR behavioral detection rules based on BloCs catch novel malware.

Q188 QUESTION

What is reverse engineering basics?

ANSWER

Basic malware reverse engineering skills for analysts: (1) Static analysis – strings.exe extracts human-readable content; (2) PESTudio – analyzes PE headers, imports, flags suspicious characteristics; (3) FLOSS (FireEye Labs Obfuscated String Solver) – extracts obfuscated strings; (4) IDA Free / Ghidra – disassemble and decompile binaries; (5) x64dbg – dynamic analysis debugger. Key indicators to find: hardcoded C2 IPs/domains, encryption keys, mutex names (for family identification), anti-analysis techniques (RDTSC timing, IsDebuggerPresent). Full RE requires specialized skills; analysts need basic static analysis capability.

Q189 QUESTION

What is malware persistence evasion techniques?

ANSWER

Advanced persistence evasion: (1) COM hijacking – replace legitimate COM object with malicious DLL; (2) DLL search order hijacking – place malicious DLL in path searched before legitimate location; (3) Boot configuration persistence – modify BCD for bootkit persistence; (4) Scheduled task disguising – name task 'Windows Update Helper', use legitimate-looking description; (5) WMI subscription – event filter/consumer/binding combination that executes PowerShell on event trigger; (6) AppCert DLLs – DLLs loaded into every process using CreateProcess API. Detection: monitor WMI subscriptions, scheduled task creation (Event 4698), registry modifications to COM objects.

11 Security Automation & SOAR

15 Qs

Q190 QUESTION

What is SOAR and how does it improve SOC efficiency?

ANSWER

SOAR (Security Orchestration Automation and Response) automates repetitive SOC tasks. Example: Phishing SOAR playbook: (1) Email reported by user; (2) SOAR extracts URLs and attachments; (3) Checks URLs in VirusTotal, URLScan.io; (4) Detonates attachment in sandbox; (5) If malicious: auto-quarantines email from all mailboxes, blocks URL in proxy, creates Jira ticket, notifies analyst on Slack; (6) If benign: auto-closes ticket. Reduces analyst time from 30 minutes to 2 minutes per phishing case.

Q191 QUESTION

What is a SOAR playbook?

ANSWER

A SOAR playbook is a codified IR workflow executed automatically. Trigger: SIEM alert. Actions: API calls to security tools, conditional logic, human approval gates. Example components: Decision nodes (if VirusTotal score > 70 → malicious branch), Actions (isolate endpoint via EDR API), Human tasks (analyst approves blocking of a critical server before isolation), Notifications (Slack/email/PagerDuty), Ticket creation (Jira/ServiceNow). Platforms: Palo Alto XSOAR, Splunk SOAR, Microsoft Sentinel Playbooks (Logic Apps).

Q192 QUESTION

What is API integration in security automation?

ANSWER

Security tools expose APIs for automation integration. Example integrations: EDR API (isolate endpoint: CrowdStrike /devices/actions/v2/contain); SIEM API (create case); Firewall API (block IP); Threat Intel API (enrich indicator: VirusTotal /files/{hash}); ITSM API (create ServiceNow ticket). Security orchestration connects these via API calls. Authentication: OAuth 2.0, API keys, JWT tokens. Always use least-privilege API keys — each integration needs only specific permissions.

Q193 QUESTION

What is threat intelligence automation?

ANSWER

Automated TI workflows: (1) TAXII client pulls new STIX bundles from feeds every hour; (2) Deduplication removes already-known indicators; (3) Enrichment adds context (geolocation, ASN, passive DNS); (4) Scoring prioritizes high-confidence IoCs; (5) Distribution pushes to SIEM (watchlists), firewall (block lists), EDR (custom IOC detection), email gateway (sender blocks). Full automation from feed to blocking in minutes vs. hours for manual process.

Q194 QUESTION

What is Python scripting for security automation?

ANSWER

Python common security automation scripts: (1) Log parsing — parse Apache/nginx logs to find attack patterns; (2) IoC extraction — extract IPs/domains/hashes from threat reports using regex; (3) API clients — requests library for VirusTotal, Shodan, SIEM APIs; (4) PCAP analysis — scapy or pyshark to process network captures; (5) Vulnerability report processing — parse Nessus XML output into ticketing system. Libraries: requests, scapy, pyshark, python-misp, cortex4py, crowdstrike-falconpy.

Q195 QUESTION

What is security metrics and KPIs?

ANSWER

Security metrics for SOC management: MTTD (mean time to detect – target <4h for critical), MTTR (mean time to respond – target <24h critical), Alert volume (trending up? investigate), True positive rate (>80% means good detection), False positive rate (>20% needs tuning), Analyst queue depth (measure overload), Patch compliance % (% systems patched within SLA), Phishing click rate (% employees clicking simulated phishes – target <5%), Vulnerability closure rate, SOC coverage % (% assets with logging enabled).

Q196 QUESTION

What is case management in SOC?

ANSWER

Case management tracks incidents through their lifecycle. Functions: case creation (from SIEM alert or manual), assignment to analyst, task tracking, evidence collection, timeline building, collaboration (comments, mentions), escalation tracking, closure with root cause, reporting. Tools: TheHive (open source), ServiceNow SecOps, IBM Resilient, Swimlane. Example: SIEM alert auto-creates TheHive case □ analyst assigned □ tasks: triage, collect evidence, contain, eradicate □ case closed with IoCs extracted and shared to MISP.

Q197 QUESTION

What is automated threat hunting?

ANSWER

Automated threat hunting schedules and runs hunts programmatically. Example: Scheduled Splunk search runs nightly: `index=sysmon EventCode=1 ParentImage=*winword.exe Image=*powershell.exe | table _time, Computer, User, CommandLine` – finds all instances of Word spawning PowerShell. Results auto-create cases in TheHive if hits found. Hunting automation converts one-time hunts into continuous detection, reducing analyst workload while increasing coverage.

Q198 QUESTION

What is deception technology automation?

ANSWER

Deception automates attacker detection via decoys. Honeytokens: fake AWS credentials deployed in code repos – any use triggers immediate alert. Canary files: fake spreadsheets with names like 'CEO_Salary_2024.xlsx' – opening triggers alert. Fake network shares: SMB shares with no legitimate users – any access = lateral movement indicator. Example: Canarytoken (free at canarytokens.org) generates a unique URL/file – accessing it sends alert with attacker IP, user agent, and timestamp.

Q199 QUESTION

What is runbook automation (RBA)?

ANSWER

Runbook automation codifies manual analyst tasks. Example runbook for 'Suspicious PowerShell Execution': (1) Query EDR for full process tree and command line; (2) Extract any URLs or file hashes from command line; (3) Check hash against VirusTotal; (4) Query SIEM for other events from same host in last 24h; (5) Check user's recent authentication events; (6) Determine if this is known-good (admin script) or suspicious; (7) If suspicious □ escalate to L2 with pre-populated summary. RBA presents all evidence in one view, reducing triage time from 20 minutes to 3 minutes.

Q200 QUESTION

What is automation-driven incident response metrics?

ANSWER

SOAR automation metrics: (1) Automation rate — % of alerts handled without analyst intervention; (2) Time savings — average analyst hours saved per month; (3) Playbook execution time — average time to complete each playbook; (4) Playbook reliability — % of playbook executions that complete without errors; (5) False positive auto-closure rate — % of FP alerts closed automatically; (6) Escalation rate — % of automated resolutions that required analyst override. Example: Before SOAR — 500 alerts/day, 30 min each = 250 analyst hours. After SOAR — 70% automated (350 auto-resolved), 150 analyst, 30 min each = 75 analyst hours. 70% efficiency gain.

Q201 QUESTION

What is threat intelligence platform (TIP) integration?

ANSWER

TIP integration architecture: (1) Input feeds — open source (AlienVault OTX, MISP communities, FS-ISAC), commercial (Recorded Future, Mandiant), government (CISA AIS, FBI InfraGard), internal (incident-derived IoCs); (2) Processing — normalization to STIX, deduplication, scoring/aging; (3) Output — SIEM watchlists, firewall block lists, EDR custom IoC, email gateway, web proxy. Example MISP workflow: receive STIX bundle from FS-ISAC → deduplicate → enrich with context → score (source reliability × recency) → auto-push IPs scoring >70 to Palo Alto EDL → push domains to Cisco Umbrella block list. Full automation from feed to blocking.

Q202 QUESTION

What is SOAR use case development?

ANSWER

SOAR use case development process: (1) Identify repetitive manual analyst tasks — triage steps that always happen; (2) Define trigger — what SIEM alert or event starts the playbook?; (3) Map required data — what enrichment is needed? (VirusTotal, CMDB, AD, Threat Intel); (4) Define decision logic — if malicious → which containment action?; (5) Define actions — block IP, isolate endpoint, create ticket; (6) Define notifications — who and how?; (7) Build in SOAR platform; (8) Test with simulated alerts; (9) Deploy and monitor; (10) Measure before/after analyst time. Start with highest-volume, most repetitive use cases (phishing triage is typically #1).

Q203 QUESTION

What is SOAR platform selection criteria?

ANSWER

SOAR platform evaluation: (1) Integration library — how many pre-built connectors? (SIEM, EDR, TIP, ITSM, email, firewall); (2) Playbook editor — visual drag-drop vs code-based; (3) Scalability — handles your alert volume?; (4) Deployment model — cloud, on-premises, hybrid?; (5) Case management — built-in or ITSM integration?; (6) Reporting — playbook metrics, ROI measurement; (7) Community — active user community, playbook sharing?; (8) Cost model — per alert, per analyst seat, enterprise license?; (9) Vendor support and roadmap. Top platforms: Palo Alto XSOAR, Splunk SOAR, Microsoft Sentinel (Logic Apps), IBM QRadar SOAR.

Q204 QUESTION

What is automated threat enrichment?

ANSWER

Threat enrichment automation adds context to IoCs automatically. Enrichment sources: VirusTotal (file hash reputation, URL scan, IP reputation), Shodan (open ports, services, banners for IPs), WHOIS (domain registration details, registrant), PassiveDNS (historical DNS records for domain or IP), AbuseIPDB (community IP abuse reports), MaxMind GeoIP (geolocation, ASN for IP), AlienVault OTX (threat pulses, associated malware). SOAR workflow: receive alert with IP → parallel enrichment from all sources → combine results → calculate composite risk score → present to analyst with full context in seconds.

12 Risk Management & Compliance

15 Qs

Q205 QUESTION

What is risk management in CySA+ context?

ANSWER

CySA+ risk management applies quantitative and qualitative risk analysis to security decisions. Quantitative: Annual Loss Expectancy (ALE) = Asset Value × Exposure Factor × Annualized Rate of Occurrence. Example: Web server worth \$100,000, 30% damage from SQL injection, 2 incidents/year □ ALE = \$60,000. Spend up to \$60,000/year on controls. Qualitative: High/Medium/Low risk matrix using likelihood vs. impact. Risk register documents all risks with owners, mitigations, and residual risk.

Q206 QUESTION

What is a security control assessment?

ANSWER

Security control assessment tests whether controls are in place and functioning. Types: (1) Review — document/interview review; (2) Test — verify control functions (test firewall blocks, test backup restoration); (3) Examine — inspect logs, configurations. NIST SP 800-53A defines assessment procedures. Example: Assessing 'AC-2 Account Management' — review account management policy (Review), test that disabled accounts cannot log in (Test), examine AD for accounts inactive >90 days (Examine).

Q207 QUESTION

What is a security audit vs assessment vs pen test?

ANSWER

Audit: formal, compliance-focused, against a standard (ISO 27001, PCI DSS) — pass/fail. Independent auditor. Assessment: broader evaluation of security posture, identifies gaps, not pass/fail. Internal or external. Penetration test: active exploitation to demonstrate real-world impact. Example: Company undergoes ISO 27001 audit (pass/fail against standard) + annual security assessment (identify gaps) + quarterly pen test (exploit gaps to show impact).

Q208 QUESTION

What is continuous compliance monitoring?

ANSWER

Continuous compliance monitoring replaces periodic point-in-time audits with automated, ongoing checks. Tools: AWS Security Hub (checks 200+ PCI/CIS controls continuously), Qualys Policy Compliance, Chef InSpec (infrastructure compliance as code). Example: Every 15 minutes, AWS Config checks if all S3 buckets have encryption enabled. Non-compliant bucket triggers alert and auto-remediation Lambda function re-enables encryption. Compliance posture visible in real-time dashboard.

Q209 QUESTION

What is a data flow diagram (DFD) and its security relevance?

ANSWER

DFD documents how data flows between processes, data stores, and external entities. Security use: identify trust boundaries, find where sensitive data is processed/stored, locate where controls must exist. Example: DFD for payment processing shows: Browser □ WAF □ Web Server □ App Server □ Database. Trust boundaries: internet/DMZ boundary (WAF), DMZ/internal boundary (firewall). Each trust boundary requires security controls (encryption in transit, input validation).

Q210 QUESTION

What is third-party risk in security operations?

ANSWER

Third-party risk: vendors, suppliers, and partners with access to your systems or data. Assessment: security questionnaire, SOC 2 report review, penetration test results, right-to-audit clause. Continuous monitoring: track vendor security news, breach notifications, SLA compliance. Example: SolarWinds supply chain attack — attackers compromised vendor's software, affecting 18,000+ downstream customers. Mitigation: vendor network segmentation, limit vendor permissions to minimum needed, monitor vendor access logs.

Q211 QUESTION

What is regulatory compliance in security operations?

ANSWER

Key regulations affecting security operations: GDPR (breach notification 72h), HIPAA (security rule, breach notification 60 days), PCI DSS (quarterly scans, annual assessment, log retention 12 months), SOX (financial system security controls, IT general controls), CMMC (US defense contractors, tiered security requirements), FedRAMP (cloud services for US federal agencies). Example: HIPAA requires covered entities to have IR procedures — including detection, reporting, containment, and breach notification.

Q212 QUESTION

What is a Business Impact Analysis (BIA) for security?

ANSWER

BIA quantifies the impact of security incidents on business functions. Determines: Maximum Tolerable Downtime (MTD), Recovery Time Objective (RTO), Recovery Point Objective (RPO), for each business process. Example: Payment processing — MTD 2 hours, RTO 30 minutes, RPO 5 minutes (last backup). These drive security control investment: high-value processes get redundant systems, more frequent backups, faster IR procedures. BIA is an input to DR planning and BCM strategy.

Q213 QUESTION

What is security governance?

ANSWER

Security governance provides oversight ensuring security aligns with business objectives. Components: (1) Security policy framework — policies, standards, procedures, guidelines; (2) Security committee — CISO, CIO, Legal, HR, business leaders; (3) Risk appetite statement — how much risk is acceptable; (4) KPIs and reporting to board; (5) Audit and compliance function. Example: Board-level security committee reviews quarterly CISO report: security metrics, major incidents, risk posture, investment recommendations.

Q214 QUESTION

What is privacy impact in security operations?

ANSWER

Security operations must balance security monitoring with privacy. Examples: Full PCAP captures contain private user data — retention and access must comply with GDPR. UEBA may process personal information — requires lawful basis. Employee monitoring policies must be disclosed. Best practices: minimize data collection to security-relevant fields, implement data retention limits, restrict access to sensitive logs (e.g., only IR leads can access email content logs), document lawful basis for each security processing activity.

Q215 QUESTION

What is risk quantification?

ANSWER

Risk quantification converts risk to financial terms for executive decision-making. FAIR (Factor Analysis of Information Risk) model: $\text{Loss Magnitude} \times \text{Loss Event Frequency} = \text{Risk}$. Example: Cloud storage breach scenario — Loss Magnitude = \$5M (legal, regulatory, customer notification), Loss Event Frequency = 15% chance in next year $\Rightarrow$ Annual Risk = \$750,000. Compare to control cost: implementing CASB + DLP costs \$200,000/year $\Rightarrow$ positive ROI. RiskLens software automates FAIR calculations. Quantification enables security to compete for budget alongside other business investments using the same financial language.

Q216 QUESTION

What is security compliance gap analysis?

ANSWER

Gap analysis compares current security posture against a target framework. Process: (1) Select framework (PCI DSS, NIST CSF, ISO 27001, CIS Controls); (2) Assess each control — Implemented, Partially Implemented, Not Implemented, Not Applicable; (3) For gaps — document current state vs. required state; (4) Prioritize gaps by risk and compliance deadline; (5) Create remediation roadmap with owners, budget, timeline; (6) Track progress over time. Example: PCI DSS gap analysis finds 23 controls not met — highest risk gap: no log monitoring (Req 10.7). Priority 1 remediation: implement SIEM with PCI log sources.

Q217 QUESTION

What is an audit response process?

ANSWER

Security audit response: (1) Pre-audit — gather evidence package (policies, configs, logs, scan reports); (2) Audit kickoff — define scope, key contacts, evidence request process; (3) Evidence provision — respond to auditor requests within agreed timeframes; (4) Findings review — review draft findings before final report; (5) Factual corrections — dispute inaccurate findings with evidence; (6) Remediation planning — for confirmed findings, develop SMART remediation plans; (7) Management response — formal response to each finding with remediation commitment; (8) Follow-up audit — demonstrate remediation completion. Key principle: no surprises — know your gaps before auditors do.

Q218 QUESTION

What is security program ROI measurement?

ANSWER

Security program ROI: (1) Cost avoidance — breach prevented $\times$ breach cost estimate (IBM benchmark: avg \$4.45M); (2) Operational efficiency — SOAR saves 200 analyst hours/month $\times$ \$75/hour = \$180,000/year; (3) Compliance cost reduction — avoiding fines (GDPR max €20M) vs. compliance program cost; (4) Insurance premium reduction — mature security posture reduces cyber insurance premiums 10-30%; (5) Audit finding reduction — fewer findings = less remediation cost. Present ROI annually to leadership: 'Security investment of \$2M prevented estimated \$8M in breach costs = 4:1 ROI.'

Q219 QUESTION

What is security control framework mapping?

ANSWER

Control framework mapping aligns controls across multiple frameworks to reduce duplication. Example: NIST CSF Protect $\Rightarrow$ maps to: ISO 27001 Annex A.9 (Access Control), CIS Controls 5-6 (Account Management), PCI DSS Requirement 7 (Access Control). Benefits: implement a control once, satisfy multiple frameworks simultaneously. Unified Control Framework (UCF) provides pre-built mappings across 50+ frameworks. Saves: avoid implementing 500 controls for NIST + 400 for ISO + 300 for PCI separately — instead implement 400 controls satisfying all three through mapping.

13 Application Security Analysis

15 Qs

Q220 QUESTION

What is the OWASP Top 10 for application security analysis?

ANSWER

OWASP Top 10 2021: (1) A01 Broken Access Control; (2) A02 Cryptographic Failures; (3) A03 Injection (SQLi, XSS, LDAP); (4) A04 Insecure Design; (5) A05 Security Misconfiguration; (6) A06 Vulnerable and Outdated Components; (7) A07 Identification and Authentication Failures; (8) A08 Software and Data Integrity Failures; (9) A09 Security Logging and Monitoring Failures; (10) A10 Server-Side Request Forgery. Example: A08 includes SolarWinds-type supply chain attacks and unsigned code updates.

Q221 QUESTION

What is web application penetration testing?

ANSWER

Web app pen test methodology (OWASP Testing Guide): (1) Reconnaissance – spider site, identify tech stack; (2) Authentication testing – test login for brute force, default creds, session fixation; (3) Authorization testing – IDOR, privilege escalation, path traversal; (4) Input validation testing – SQLi, XSS, command injection, XXE; (5) Session management – cookie security flags, session timeout, CSRF; (6) Business logic testing – skip payment steps, negative pricing. Tools: Burp Suite Pro, OWASP ZAP, sqlmap, nikto.

Q222 QUESTION

What is API security testing?

ANSWER

API security testing follows OWASP API Security Top 10. Methods: (1) Broken Object Level Authorization (BOLA) – change resource ID in request (/api/users/123 → /api/users/456); (2) Mass assignment – send additional fields not expected by API to modify unintended attributes; (3) Excessive data exposure – API returns more fields than the UI displays (raw response may contain hidden sensitive data); (4) Rate limiting – fuzz API endpoints to find missing rate limits; (5) Authentication bypass – test API keys, JWT manipulation. Tools: Postman, Burp Suite, OWASP ZAP.

Q223 QUESTION

What is SAST in application security?

ANSWER

SAST (Static Application Security Testing) analyzes source code, bytecode, or binary for vulnerabilities without execution. Tools: Semgrep (open source, fast, many rules), SonarQube (code quality + security), Checkmarx, Fortify, Veracode. Integration: run in CI pipeline on every pull request. Findings: SQLi (string concatenation into SQL queries), XSS (unescaped user input in HTML output), hardcoded secrets (API keys, passwords in code), insecure crypto (MD5, DES usage). False positive management is critical – developers lose trust if too many FPs.

Q224 QUESTION

What is DAST in application security?

ANSWER

DAST (Dynamic Application Security Testing) tests running applications by sending malicious inputs. Tools: OWASP ZAP (open source, CI-friendly), Burp Suite (manual + automated), Invicti, Rapid7 AppSpider. Process: crawl application, fuzz parameters with attack payloads, analyze responses for vulnerability indicators. Advantages over SAST: finds runtime issues (authentication state issues, race conditions), more accurate (sees actual behavior). Limitation: can't see server-side code, misses logic flaws.

Q225 QUESTION

What is a web application firewall (WAF) analysis?

ANSWER

WAF analysis for security operations: (1) Review WAF logs for blocked attacks – spikes indicate active scanning or exploitation; (2) Identify bypass attempts – encoded payloads (double URL encoding, hex encoding); (3) False positive analysis – legitimate traffic blocked; (4) Rule gap analysis – attacks in application logs that WAF didn't block; (5) Tune rules – reduce FPs, add custom rules for application-specific attacks. Example: WAF logs show 50,000 blocked SQLi attempts from single IP → block IP, investigate if any bypassed WAF, review application logs for successful exploitation.

Q226 QUESTION

What is a secure code review?

ANSWER

Secure code review manually examines source code for security vulnerabilities that automated tools miss. Focus areas: authentication and session management, authorization checks (every endpoint has access control?), input validation and output encoding, cryptography (key management, algorithm choices), error handling (sensitive data in error messages?), third-party library usage, business logic flaws. Tools assist: SAST for initial findings, developer reviews false positives and missed issues. Effectiveness: skilled reviewer finds 50% more vulnerabilities than SAST alone.

Q227 QUESTION

What is server-side request forgery (SSRF)?

ANSWER

SSRF makes the server perform requests to attacker-controlled destinations. Example: Application fetches URL from user input – attacker provides `http://169.254.169.254/latest/meta-data/` (AWS IMDS) → server retrieves and returns IAM credentials. Impact: cloud credential theft, internal service enumeration, bypass firewalls, SSRF to RCE. Detection: WAF rules blocking private IP ranges in URL parameters, application logs for IMDS requests. Mitigation: whitelist allowed URLs, disable URL-fetching features if not needed.

Q228 QUESTION

What is a bug bounty program analysis?

ANSWER

Bug bounty programs invite external researchers to find vulnerabilities. Platform: HackerOne, Bugcrowd, Synack. Analyst role: triage incoming reports (valid, duplicate, out-of-scope), reproduce findings, assess severity (CVSS), assign to development team, verify fix, pay bounty. Common findings: IDOR, XSS, SSRF, authentication bypass, subdomain takeover. Metrics: mean time to triage (MTTT), mean time to resolve, bounty paid vs. pen test cost comparison.

Q229 QUESTION

What is container image security analysis?

ANSWER

Container image analysis examines Docker/OCI images for vulnerabilities and misconfigurations. Tools: Trivy (open source, fast), Anchore, Snyk Container, Gype. Checks: OS package CVEs, application dependency CVEs, secrets in image layers, running as root, dangerous capabilities. Example: Trivy scan of `ubuntu:20.04` base image finds 25 CVEs including 2 critical – update to `ubuntu:22.04` or apply patches. CI/CD integration: fail pipeline if critical CVEs found, preventing vulnerable images from deploying.

Q230 QUESTION

What is HTTP request smuggling?

ANSWER

HTTP request smuggling exploits ambiguity in how front-end and back-end servers interpret HTTP message boundaries. Example: Attacker sends a request with conflicting Content-Length and Transfer-Encoding headers — front-end (load balancer) sees one request, back-end sees two requests — second 'smuggled' request is prepended to the next legitimate user's request, potentially hijacking their session or bypassing access controls. Detection: WAF logs for malformed HTTP headers, anomalous request sequences. Portswigger Web Security Academy has comprehensive smuggling labs.

Q231 QUESTION

What is insecure deserialization detection?

ANSWER

Deserialization vulnerabilities occur when untrusted data is deserialized into an object, potentially executing attacker-controlled code. Example: Java application deserializes a user-provided Base64 object ▯ attacker provides a malicious serialized object that calls Runtime.exec() during deserialization ▯ Remote Code Execution. Detection: look for serialized Java objects (Base64 starting with rOO, hex starting with ACED0005) in user-controllable input fields, HTTP request bodies, cookies. SAST tools flag unsafe deserialization patterns; DAST tools send known gadget chains.

Q232 QUESTION

What is GraphQL security testing?

ANSWER

GraphQL APIs have unique security testing considerations: (1) Introspection — enabled by default, reveals entire schema (disable in production); (2) Excessive data exposure — single query can retrieve deeply nested data exposing sensitive fields; (3) Injection — GraphQL queries passed to resolvers that construct SQL/NoSQL queries; (4) Denial of service — deep nested queries cause N+1 database query amplification; (5) Authorization — each resolver must independently verify authorization (field-level authorization). Testing tools: InQL (Burp Suite extension), GraphQL Voyager for visualization, altair GraphQL client.

Q233 QUESTION

What is secure development training for developers?

ANSWER

Developer security training content: (1) OWASP Top 10 — what each vulnerability is and how to prevent it; (2) Secure coding practices — parameterized queries, output encoding, input validation; (3) Secrets management — never commit credentials, use vaults; (4) Dependency management — SCA scanning, update policy; (5) Threat modeling basics — how to think about security during design; (6) Secure code review — what to look for. Training delivery: annual formal training + hands-on labs (DVWA, WebGoat) + IDE security plugins (Snyk, SonarLint) + code review feedback. Measure: reduction in SAST findings per developer over time.

Q234 QUESTION

What is DAST in CI/CD pipeline?

ANSWER

DAST integration in CI/CD: (1) Deploy application to staging environment; (2) Run DAST scan (OWASP ZAP, Burp Suite Enterprise in CI mode) against staging URL; (3) Parse results — filter by severity threshold (fail build if Critical/High found); (4) Create tickets for findings below threshold; (5) Generate trend report (new findings vs. fixed vs. carried). Challenges: authenticated scanning requires test credentials; dynamic content may not be fully crawled; scan duration (20-60 minutes) adds to pipeline time. Solution: run DAST scans in parallel with other pipeline stages to minimize delay.

14 CySA+ CS0-003 Exam Focus

16 Qs

Q235 QUESTION

What is the CompTIA CySA+ CS0-003 exam format?

ANSWER

CS0-003 consists of up to 85 questions (multiple choice + performance-based), 165-minute time limit, passing score 750/900. Recommended experience: 3-4 years IT security or relevant certifications (Security+, Network+). Domains: (1) Security Operations 33%, (2) Vulnerability Management 30%, (3) Incident Response & Management 20%, (4) Reporting & Communication 17%. Hands-on performance-based questions simulate real analyst tasks using tools like Wireshark, SIEM, and vulnerability scanners.

Q236 QUESTION

What are the four CySA+ CS0-003 exam domains?

ANSWER

(1) Security Operations 33%: threat intelligence, threat hunting, network security monitoring, log analysis, endpoint security, UEBA, SOAR; (2) Vulnerability Management 30%: scanning, prioritization, remediation, SCA, DAST/SAST, attack surface management; (3) Incident Response & Management 20%: IR lifecycle, forensics, containment, eradication, communication; (4) Reporting & Communication 17%: metrics, dashboards, executive reporting, remediation recommendations, vulnerability disclosure.

Q237 QUESTION

What changed from CS0-002 to CS0-003?

ANSWER

CS0-003 key changes: (1) Increased SOAR and automation content; (2) Cloud security analysis added (cloud-native logging, CSPM); (3) Threat intelligence sharing (STIX/TAXII, TLP) expanded; (4) Attack surface management added; (5) Reporting and communication elevated to its own domain; (6) CTI (Cyber Threat Intelligence) given more weight; (7) Removed some legacy topics; (8) Added XDR, deception technology; (9) Greater emphasis on proactive threat hunting vs reactive detection.

Q238 QUESTION

What is a performance-based question on CySA+?

ANSWER

PBQs simulate analyst tasks. Examples: (1) Analyze a Wireshark PCAP and identify the attack type (look for SYN flood, SQL injection in HTTP, DNS tunneling); (2) Review SIEM alerts and determine which is a true positive; (3) Interpret Nessus scan results and prioritize vulnerabilities for remediation; (4) Write a YARA rule to detect a malware family; (5) Map attack indicators to MITRE ATT&CK; techniques; (6) Create a correlation rule in a mock SIEM interface. PBQs appear at start – attempt all, mark for review if unsure.

Q239 QUESTION

What is the CySA+ approach to threat analysis questions?

ANSWER

CySA+ threat analysis questions test: reading logs and identifying attack patterns, understanding MITRE ATT&CK; tactic for a given technique, identifying IoCs from descriptions, distinguishing threat actor motivations, applying the diamond model. Tips: know the difference between tactics (goals) and techniques (methods), understand common attack patterns (brute force, lateral movement, exfiltration), be able to read and interpret common log formats (Windows Event ID, Syslog, firewall log, proxy log).

Q240 QUESTION

What are key tools and technologies tested on CySA+?

ANSWER

CySA+ tool knowledge: Nessus/Qualys (vulnerability scanning), Wireshark/tcpdump (packet analysis), Splunk/Elastic (SIEM), Zeek/Snort/Suricata (network monitoring), MISP/ThreatConnect (TIP), Maltego (OSINT/link analysis), Autopsy/FTK (digital forensics), Volatility (memory forensics), Burp Suite/ZAP (web app testing), CrowdStrike/SentinelOne (EDR), nmap (discovery), Metasploit (exploitation awareness), OWASP ZAP (DAST), Semgrep/SonarQube (SAST).

Q241 QUESTION

What are reporting and communication skills tested on CySA+?

ANSWER

Domain 4 (Reporting & Communication) tests: writing vulnerability reports with business impact and remediation steps; creating executive summaries for non-technical audiences; defining SLA metrics; communicating risk in business terms (not just CVSS scores); presenting incident timelines; dashboarding security metrics; writing effective remediation recommendations that get prioritized. Tip: CySA+ expects you to translate technical findings into business impact — 'CVSS 9.0 SQLi' becomes 'Attacker can steal all customer data and payment information.'

Q242 QUESTION

What is the CySA+ study approach?

ANSWER

Study strategy: (1) Read Mike Chapple & David Seidl CySA+ Study Guide; (2) Use Jason Dion practice exams (Udemy); (3) Hands-on: set up Splunk free (500MB/day), import log samples, create correlation rules; (4) Practice Wireshark with sample PCAPs (Wireshark wiki); (5) Set up Metasploitable VM, run Nessus against it, practice vulnerability management; (6) Study MITRE ATT&CK; — map techniques to detection methods; (7) Practice writing incident reports with findings + business impact + recommendations.

Q243 QUESTION

What is the exam day strategy for CySA+?

ANSWER

Exam strategy: (1) Read questions fully — watch for 'BEST', 'FIRST', 'MOST LIKELY'; (2) PBQs first — don't spend >15 minutes on one; (3) For analysis questions — eliminate impossible answers first; (4) When two answers seem correct — choose the one addressing the root cause or most complete solution; (5) Don't overthink simple questions; (6) Mark for review and return; (7) Know acronyms cold — SOAR, UEBA, STIX, TAXII, SIEM, TTP, IoC, TTI, ATT&CK; Time management: 165 minutes for 85 questions = ~2 minutes each.

Q244 QUESTION

What is the difference between CySA+ and Security+?

ANSWER

Security+ (SY0-701): foundational, broad coverage of security concepts, entry-level analyst role. CySA+: intermediate, analysis and response focused, requires hands-on skills. Key differences: CySA+ requires reading/interpreting logs, writing correlation rules, conducting threat hunts, vulnerability prioritization, forensic analysis — Security+ tests recognition of concepts. CySA+ is appropriate for: SOC analyst L2/L3, threat analyst, vulnerability analyst, IR analyst. Recommended path: CompTIA A+ □ Network+ □ Security+ □ CySA+ □ CASP+.

Q245 QUESTION

What is the CySA+ approach to SOAR questions?

ANSWER

SOAR questions test understanding of automation concepts and workflow design. Key concepts: playbook triggers (SIEM alert, scheduled, manual), enrichment actions (threat intel APIs, CMDB lookups), decision logic (if/then based on scores or data), response actions (block IP, isolate, create ticket), human-in-the-loop approval points. CySA+ may ask: 'Which step should be automated vs require human approval?' Answer: automated for initial triage and low-risk containment; human approval for actions affecting critical production systems or irreversible actions.

Q246 QUESTION

What is the CySA+ approach to forensics questions?

ANSWER

Forensics questions test: order of volatility (always RAM before disk), evidence preservation procedures (write blockers, chain of custody), artifact knowledge (Windows event IDs, registry keys, prefetch, \$MFT), tool selection (Autopsy for disk, Volatility for memory, Wireshark for PCAP), and legal considerations. Example question: 'An analyst needs to collect evidence from a running server while minimizing disruption. What should be collected first?' Answer: RAM/memory (most volatile, contains running processes, network connections, encryption keys) — disk can be imaged later without powering down.

Q247 QUESTION

What is the CySA+ approach to reporting questions?

ANSWER

Domain 4 reporting questions test: ability to translate technical findings to business impact, structure vulnerability and incident reports, recommend remediation actions, and choose appropriate communication for audience. Example: Given a list of 10 vulnerabilities, select which to include in an executive report (hint: focus on business risk and remediation ROI, not technical severity alone). Know: executive summary requires business impact; technical report requires CVE details and proof-of-concept; remediation recommendation requires specific actionable steps with timeline and effort estimate.

Q248 QUESTION

What is the CySA+ networking knowledge required?

ANSWER

CySA+ requires applied networking knowledge: (1) TCP/IP protocol stack and headers (identify port scans from SYN flags in Wireshark); (2) Common ports and protocols (DNS 53, HTTP 80, HTTPS 443, SMB 445, RDP 3389); (3) IPv4 subnetting and CIDR notation; (4) ARP — and why ARP poisoning works; (5) DNS — resolution process and why DNS is used for C2; (6) HTTP — request/response structure, methods (GET/POST), status codes; (7) TLS — handshake understanding for JA3 fingerprinting; (8) NetFlow — what information is captured. Practical: practice reading Wireshark and interpreting TCP conversations.

Q249 QUESTION

What is the CySA+ cloud security knowledge required?

ANSWER

CySA+ cloud content (CS0-003 emphasis): (1) Shared responsibility model — know what customer vs. provider is responsible for in IaaS/PaaS/SaaS; (2) Cloud security tools — CASB (discover shadow IT, enforce DLP), CSPM (misconfiguration detection), CWPP (workload protection); (3) Cloud logging — CloudTrail for AWS API calls, Azure Activity Log, cloud-native SIEM integration; (4) Cloud IAM — role-based access, service accounts, access keys; (5) Common cloud misconfigurations — public S3, open security groups, no MFA on root; (6) Container security basics — image scanning, runtime security, Kubernetes network policies.

Q250 QUESTION

What is the CySA+ recommended study timeline?

ANSWER

CySA+ study timeline for Security+ holders: 8-12 weeks. Week 1-2: Threat Intelligence and SIEM (read chapters + Splunk hands-on); Week 3-4: Vulnerability Management (Nessus scan lab, CVSS scoring practice); Week 5-6: Incident Response (tabletop scenarios, forensics tools); Week 7-8: Network and Endpoint Security Analysis (Wireshark PCAPs, EDR alert analysis); Week 9: Cloud Security and Automation (AWS free tier, SOAR concepts); Week 10: Reporting and Communication (practice writing findings); Week 11-12: Practice exams (Jason Dion on Udemy, Professor Messer), review weak areas. Schedule exam for end of week 12. Target: 85%+ on practice exams before scheduling real exam.

15 Reporting & Communication

16 Qs

Q251 QUESTION

What is security reporting for executives?

ANSWER

Executive security reports translate technical findings into business language. Elements: key risk indicators (not raw CVE counts), business impact statements ('this vulnerability could expose customer payment data'), trend analysis (are we improving?), resource needs and ROI, upcoming compliance deadlines. Example: Instead of 'We found CVE-2023-44487 with CVSS 7.5,' write: 'A critical vulnerability in our web servers could allow attackers to take them offline, impacting \$50,000/hour revenue. Remediation costs \$5,000 and requires 2-hour maintenance window.'

Q252 QUESTION

What is a vulnerability report structure?

ANSWER

Vulnerability report sections: (1) Executive Summary — overall risk posture, critical findings count, remediation priority; (2) Methodology — scope, tools, dates, type of scan; (3) Findings by severity — each finding with: title, CVE, CVSS, affected systems, description, business impact, remediation steps, references; (4) Trend analysis — comparison to previous scan; (5) Recommendations — prioritized action items; (6) Appendix — full technical details, raw tool output. Example: Finding: 'Apache Log4j RCE (CVE-2021-44228) on prod-web-01 — allows remote code execution by unauthenticated attacker.'

Q253 QUESTION

What is an incident report?

ANSWER

Incident report structure: (1) Incident summary — what happened, when, who was affected; (2) Timeline — chronological sequence of events (initial access to discovery to containment); (3) Scope — number of affected systems, data exposure assessment; (4) Root cause analysis — what vulnerability/process failure enabled the incident; (5) Impact assessment — business impact (downtime, data exposure, financial); (6) Response actions taken — containment, eradication, recovery; (7) Recommendations — preventive controls to avoid recurrence; (8) Lessons learned.

Q254 QUESTION

What is security metrics communication?

ANSWER

Security metrics for different audiences: Technical (SOC): EPS, FP rate, MTTD, MTTR, rules fired. Management: MTTD trend, incident count by severity, SLA compliance %, patch compliance %, critical open vulnerabilities. Executive/Board: breach likelihood reduction, financial risk reduction, compliance status, security maturity score, peer benchmarking. Example: Board metric — 'Our MTTD improved from 72 hours to 4 hours, reducing average breach cost by \$2.4M based on IBM benchmark data.'

Q255 QUESTION

What is stakeholder communication during an incident?

ANSWER

Incident communication plan: Internal stakeholders — IT (technical updates every 2 hours), CISO (immediate for P1, hourly updates), Legal (breach notification decisions), HR (insider threat cases), PR (public statement preparation). External — Customers (clear, factual, what happened, what we're doing, what they should do), Regulators (per notification requirements), Media (through PR, consistent messaging), Law enforcement (factual, coordinate investigation). Golden rule: communicate early, accurately, and with clear next steps — don't over-promise.

Q256 QUESTION

What is a remediation recommendation report?

ANSWER

Remediation recommendation format: (1) Vulnerability summary — what was found; (2) Risk statement — likelihood × impact in business terms; (3) Recommended fix — specific technical action (patch version X, configuration change, architectural change); (4) Alternative mitigations — if immediate fix not possible (WAF rule, network isolation); (5) Priority — critical/high/medium/low with justification; (6) Effort estimate — hours, impact, who is responsible; (7) Verification method — how to confirm remediation worked. Example: 'Patch Log4j to version 2.17.1 — 2-hour maintenance window, 5 servers, DevOps team — verify by rescan.'

Q257 QUESTION

What is dashboard design for security operations?

ANSWER

SOC dashboard design principles: (1) Real-time operational metrics for analysts — open alerts, queue depth, active incidents; (2) Management dashboards — 24h/7d/30d trend views, SLA compliance; (3) Executive dashboards — 30d/90d trends, compliance status, risk posture; (4) Alert on thresholds — red/yellow/green status indicators; (5) Drilldown capability — click metric to see underlying data. Tools: Splunk dashboards, Grafana + Elastic, Microsoft Sentinel workbooks, Power BI for executive reporting. Keep simple — max 6-8 metrics per view.

Q258 QUESTION

What is threat intelligence reporting?

ANSWER

TI reporting formats: (1) Strategic report — monthly, for CISO/leadership, threat landscape overview, geopolitical context, sector-specific threats; (2) Tactical report — weekly/bi-weekly, for security team, active campaigns, new TTPs, actor profiles; (3) Technical report — as needed, for analysts and engineers, specific IoCs, YARA rules, Snort signatures, detection recommendations; (4) Flash report — immediate, high-priority alert, zero-day or active campaign targeting your sector. Each report should include: confidence level, TLP classification, recommended actions.

Q259 QUESTION

What is vulnerability disclosure notification?

ANSWER

Vulnerability disclosure communication: (1) Internal notification — immediate to system owner, management; (2) Remediation timeline — based on severity SLA; (3) Risk acceptance process — if patching delayed, document risk acceptance with owner signature; (4) External notification — if vulnerability involves a vendor: report to vendor via their security disclosure process (security@vendor.com, HackerOne), agree on disclosure timeline (typically 90 days); (5) Customer notification — if vulnerability exposed customer data, notify per breach notification laws and contractual obligations.

Q260 QUESTION

What is a security scorecard?

ANSWER

Security scorecard rates security posture across domains with quantitative scores. Example: 100-point scale across 10 categories: Vulnerability Management (current score 72/100 — 28 unpatched critical CVEs), Patch Compliance (85/100), Phishing Resistance (65/100 — 12% click rate), MFA Adoption (90/100 — 95% coverage), Incident Response (80/100 — MTTR 4 hours). Overall score: 78/100. Trend: improving 5 points from last quarter. Used for: internal benchmarking, board reporting, cyber insurance applications.

Q261 QUESTION

What is a penetration testing report?

ANSWER

Penetration test report structure: (1) Executive Summary – overall risk rating, top 3-5 findings in business terms, key recommendations; (2) Scope and methodology – what was tested, what tools used, what was excluded; (3) Findings summary – all findings sorted by risk (Critical □ High □ Medium □ Low □ Informational); (4) Finding detail – for each: title, severity, affected systems, description, proof (screenshot, payload), business impact, remediation recommendation; (5) Appendix – full tool output, engagement timeline, rules of engagement. Style: factual, reproducible, actionable. Avoid: excessive jargon, vague recommendations.

Q262 QUESTION

What is security exception management?

ANSWER

Exception management process: (1) Exception request submitted by system owner with: vulnerability details, business justification, compensating controls, remediation timeline; (2) Security team reviews: is compensating control adequate? Is timeline reasonable? What is residual risk?; (3) Risk owner (CISO or delegated) approves or denies; (4) Exception documented in risk register with review date; (5) Compensating control verified and monitored; (6) Exception expires at review date – must be resubmitted with updated status; (7) Track exception volume and aging – too many exceptions indicates systemic patching problem.

Q263 QUESTION

What is threat intelligence report templates?

ANSWER

Threat intelligence report format: (1) Header – TLP classification, date, author, confidence level; (2) Executive summary – threat overview, key implications, recommended actions (2-3 sentences for each audience); (3) Background – context on threat actor or campaign; (4) Technical analysis – TTPs mapped to ATT&CK, malware details, infrastructure; (5) Indicators of Compromise – formatted table: IoC type, value, first seen, confidence, context; (6) Recommendations – detection rules, hunting queries, configuration changes; (7) References. Tailor detail level to audience: full technical for SOC, summary for management.

Q264 QUESTION

What is key performance indicator (KPI) selection for security?

ANSWER

Security KPI selection criteria: (1) Actionable – analyst/manager can take action based on the metric; (2) Measurable – can be quantified consistently; (3) Relevant – aligns with security program goals; (4) Timely – available frequently enough to drive decisions. Good KPIs: MTTD (measures detection speed – improves with better tools/rules), Patch compliance % (measures VM effectiveness), Phishing click rate (measures training effectiveness). Bad KPIs: number of security events (not actionable – just noise volume), number of security tools (more tools ≠ more security). Review KPI set quarterly to ensure alignment with current priorities.

Q265 QUESTION

What is documentation for security operations?

ANSWER

Security operations documentation types: (1) Runbooks – step-by-step procedures for specific tasks (how to isolate an endpoint in CrowdStrike, how to block IP in Palo Alto); (2) Playbooks – full IR workflows for incident types; (3) Knowledge base – known false positives, recurring issues, system configurations; (4) Architecture diagrams – current security tool stack and data flows; (5) Contact lists – escalation tree, vendor contacts, law enforcement liaison. Documentation principles: version controlled (Git), reviewed quarterly, owned by specific role, tested in exercises to verify accuracy. Undocumented processes leave gaps when key personnel are unavailable.

Q266 QUESTION

What is security newsletter for awareness?

ANSWER

Monthly security newsletter format for employees: (1) Threat of the month — recent real attack relevant to company (phishing, BEC, ransomware) in plain language; (2) Did you know? — one security tip or best practice; (3) Phishing simulation results — company click rate trend (anonymized); (4) Security wins — incident prevented, colleague who reported a phishing attempt; (5) Upcoming training deadlines; (6) Quick quiz — test retention of last month's tip. Keep it under 500 words, visually engaging, no jargon. Measure: open rate (target >60%), quiz completion, phishing click rate trend. Most impactful security awareness channel after simulations.

16 Advanced Threat Detection Techniques

18 Qs

Q267 QUESTION

What is deception-based detection?

ANSWER

Deception technology detects attackers by creating fake assets that only adversaries interact with. Types: Honeypots (fake servers), Honeynets (networks of honeypots), Honeytokens (fake credentials, files, URLs), Canary tokens (URLs, files, AWS keys that alert when accessed). Example: Deploy fake SSH server on 10.0.0.200 (no legitimate system uses this IP) – any connection is an attacker doing lateral movement. Zero false positives – no legitimate user should ever touch a decoy.

Q268 QUESTION

What is machine learning in threat detection?

ANSWER

ML models detect threats that rule-based systems miss. Use cases: (1) Anomaly detection – UEBA baseline modeling; (2) Malware classification – binary classification using static features (import table, entropy, section names); (3) DGA detection – train model to distinguish legitimate from DGA domains using entropy, n-gram analysis; (4) Spam/phishing classification – NLP analysis of email content; (5) Network anomaly detection – cluster analysis of NetFlow. Challenge: ML models can be poisoned, evaded (adversarial ML), and are black boxes.

Q269 QUESTION

What is sigma and detection rule engineering?

ANSWER

Sigma is a generic, vendor-neutral detection rule language for log-based detection. Rules describe log patterns in YAML format and convert to SIEM-specific syntax. Example Sigma rule: detection: selection: EventID: 4688 CommandLine|contains: '-EncodedCommand' condition: selection. Converts to Splunk SPL, KQL (Sentinel), Elastic Query DSL. Benefits: write once, deploy anywhere. Sigma rules shared on GitHub (SigmaHQ repository) and threat intelligence feeds.

Q270 QUESTION

What is network anomaly detection?

ANSWER

Network anomaly detection identifies deviations from established baseline traffic patterns. Methods: (1) Statistical – flag traffic exceeding N standard deviations from mean; (2) Clustering – group similar connections, flag outliers; (3) Rule-based – explicit rules (new protocol not seen before); (4) ML-based – unsupervised learning identifies novel patterns. Example: Server that normally sends 10 MB/hour to internet suddenly sends 10 GB in 30 minutes □ anomaly detected □ potential data exfiltration alert triggered for analyst investigation.

Q271 QUESTION

What is behavioral detection vs signature detection?

ANSWER

Signature detection: matches known patterns (hash, string, byte sequence) – fast, low FP, misses unknown threats. Behavioral detection: monitors actions and sequences – 'process injected code into another process' or 'encrypted 10,000 files in 5 minutes' – catches novel threats, higher FP risk. Example: Signature catches known Emotet hash. Behavioral catches a new, unknown packer with same behavior (PowerShell download + inject + beacon). Modern EDR combines both: signature for speed, behavioral for zero-days.

Q272 QUESTION

What is purple team operations?

ANSWER

Purple teaming combines red team (offense) and blue team (defense) to improve detection. Process: (1) Red team executes a specific technique (e.g., T1055 Process Injection); (2) Blue team checks if they detected it in SIEM/EDR; (3) If not detected — analyze why (log gap? rule gap?); (4) Develop new detection rule; (5) Red team re-executes to verify detection; (6) Document gaps and improvements. More efficient than traditional red vs. blue — collaborative improvement vs. adversarial game.

Q273 QUESTION

What is threat emulation and breach and attack simulation (BAS)?

ANSWER

BAS platforms continuously simulate attack techniques to test detection and prevention controls. Tools: SafeBreach, AttackIQ, Cymulate. Process: execute MITRE ATT&CK; techniques against production defenses (safely), measure what was detected vs. blocked vs. missed, generate gap reports, prioritize control improvements. Example: BAS executes T1059.001 (PowerShell execution), T1071.001 (HTTP C2), T1041 (exfiltration over C2) — reports that SIEM detected 7/10 techniques, 3 missed □ hunt those gaps.

Q274 QUESTION

What is deobfuscation for detection?

ANSWER

Attackers obfuscate commands to evade detection. Defenders must deobfuscate to understand and detect. Examples: PowerShell encoding — base64 decode the -EncodedCommand value; JavaScript packer — emulate execution in browser console or use js-beautify; string reversal/substitution — CyberChef applies multiple transforms; XOR encoding — try common XOR keys (0x00-0xFF). Detection tip: alert on base64-encoded PowerShell regardless of content — legitimate admins rarely use encoded PowerShell.

Q275 QUESTION

What is DNS security analysis?

ANSWER

DNS security analysis detects malicious use of DNS. Detections: (1) DGA domains — high entropy, numeric-heavy, random-looking domain names; (2) DNS tunneling — base64 subdomains, >100 character queries, TXT record exfiltration; (3) Fast flux — rapidly changing IP records evading blacklists; (4) C2 beaconing — DNS requests to same domain every N seconds; (5) Typosquatting — domains similar to legitimate ones; (6) Newly registered domains (NRD) — malware often uses fresh domains. Tools: Zeek DNS logs, PassiveDNS, DNSDB, Farsight DNSDB.

Q276 QUESTION

What is email security analysis?

ANSWER

Email security analysis detects phishing, BEC, and malware delivery. Key artifacts: Email headers (Received headers trace routing, SPF/DKIM/DMARC authentication results), URLs (extract and analyze in URLScan.io, VirusTotal), Attachments (hash lookup, sandbox detonation), Sender analysis (display name vs actual email mismatch). Example: Email from 'CEO' (display name) but sender is ceo@company.com.ru □ SPF fail □ DMARC reject □ blocked. Header analysis skill: trace the email hop-by-hop using Received headers.

Q277 QUESTION

What is file hash analysis and VirusTotal?

ANSWER

File hash analysis verifies file integrity and identifies malware. MD5/SHA-1 (legacy, collision-prone), SHA-256 (current standard), SHA-3, SSDEEP (fuzzy hash for similar files). VirusTotal checks hash against 70+ antivirus engines. VT also analyzes behavior, extracts network IoCs, shows YARA rule matches, provides community comments. Example: Suspicious file hash f3a2b8c1... n VirusTotal: 45/72 engines detect as Ryuk ransomware, drops network connections to 185.x.x.x, creates Run key for persistence n confirmed malicious.

Q278 QUESTION

What is honeypot log analysis?

ANSWER

Honeypot logs reveal attacker TTPs without risk to real systems. Analysis: (1) Credential attempts — which usernames/passwords tried (track top credentials over time); (2) Exploits used — which CVEs do attackers probe first?; (3) Post-exploitation behavior — what do attackers do after gaining access?; (4) Tool identification — which tools (scanners, exploit frameworks) used?; (5) C2 infrastructure — what IPs do attackers connect to for staging? Example: Kippo SSH honeypot logs show 90% of brute-force attempts try 'admin/admin' and 'root/123456' first.

Q279 QUESTION

What is honeypot log analysis?

ANSWER

Honeypot logs reveal attacker behavior in a safe environment. Analysis insights: (1) Credential analysis — top username/password combinations tried (build weak credential detection based on actual attack patterns); (2) Exploit timeline — how quickly are newly disclosed CVEs weaponized? (Typically <24h for critical CVEs); (3) Post-exploitation TTPs — what do attackers do once they gain access? (drop malware, add SSH keys, scan network); (4) C2 infrastructure — staging servers attackers connect to; (5) Tool identification — which scanner, exploit framework is used. Example: Cowrie SSH honeypot logs show attackers immediately try 'wget http://185.x.x.x/miner.sh' after login — classic crypto mining dropper pattern.

Q280 QUESTION

What is purple team exercise planning?

ANSWER

Purple team exercise planning: (1) Select target TTPs from threat intelligence (focus on likely threats to your sector); (2) Map to MITRE ATT&CK; (3) Define success criteria — alert generated within N minutes? Analyst responds within SLA?; (4) Red team executes technique in controlled way (notify IR team to prevent real IR response); (5) Blue team attempts detection in real time; (6) Assess detection — SIEM alert fired? EDR alerted? Alert triaged correctly?; (7) If missed — analyze log gap or rule gap; (8) Create/tune detection rule; (9) Re-execute to verify; (10) Document all gaps and improvements. Run monthly for top-priority TTPs.

Q281 QUESTION

What is continuous control monitoring?

ANSWER

Continuous control monitoring (CCM) automates verification that security controls are functioning correctly. Examples: (1) Firewall rule verification — automated test sends traffic that should be blocked; alert if traffic passes through; (2) EDR coverage — query which endpoints have EDR agent active; alert on gaps; (3) Patch compliance — automated scan verifies critical patches applied within SLA; (4) MFA enforcement — daily check that all privileged accounts require MFA; (5) Backup integrity — automated restore test weekly. CCM replaces annual point-in-time control testing with continuous assurance. Tools: Prowler (AWS), ScoutSuite, Chef InSpec, custom scripts.

Q282 QUESTION

What is red team vs blue team vs purple team?

ANSWER

Red team: offensive security team simulating adversaries — goal is to breach defenses and demonstrate real impact. Blue team: defensive security team responsible for detection and response — goal is to detect and contain threats. Purple team: collaborative exercise where red and blue work together — red executes specific technique, blue observes if it's detected, gaps are immediately addressed. Red-Blue: adversarial (realistic but inefficient for improving coverage). Purple: collaborative (less realistic but rapidly improves detection). Best practice: red-blue exercises for annual realism testing, purple team for continuous detection improvement.

Q283 QUESTION

What is MITRE ATT&CK; Navigator?

ANSWER

ATT&CK; Navigator is a web-based tool for annotating and visualizing ATT&CK; matrices. Use cases: (1) Threat actor profiling — color techniques used by APT29 in red; (2) Defensive coverage mapping — color techniques with detection capability in blue; (3) Gap analysis — overlay: red (threat actor) vs. blue (coverage) □ yellow = covered, red = gap; (4) Purple team planning — select uncovered techniques for next hunt; (5) Vendor evaluation — map product's detection claims to ATT&CK.; Free tool at attack.mitre.org/resources/attack-navigator. Exportable as JSON for sharing or SVG for reports.

Q284 QUESTION

What is false positive management in detection?

ANSWER

False positive management reduces alert fatigue while maintaining detection coverage. Process: (1) Track FP rate by rule — which rules generate most FPs?; (2) Analyze FP patterns — specific user, asset, time, or context triggers FP?; (3) Tuning options: add exception (exclude known scanner IP), refine condition (require additional context), adjust threshold (increase failed login count), retire rule if fundamentally broken; (4) Document all exceptions with justification and review date; (5) Test tuned rule against historical FP events (do they still fire?) and TP events (do they still detect?); (6) Monitor FP rate after tuning. Target: <10% FP rate per rule. High-FP rules generate noise and reduce analyst trust in all alerts.

17 Scenario-Based & Practical

16 Qs

Q285 QUESTION

You receive a SIEM alert: 50 failed logins then 1 success on an admin account at 3 AM. What do you do?

ANSWER

Response: (1) Immediately verify: pull auth logs — which IP? Which systems subsequently accessed? (2) Check: is admin account from known IP range? Known admin working late? (3) If suspicious: immediately lock the account and terminate active sessions; (4) Check for persistence — new accounts created, services installed, scheduled tasks in the 3 AM window; (5) Memory image of suspect systems; (6) Check lateral movement — did this account connect to other systems after 3 AM?; (7) Escalate to L2 with timeline; (8) Notify account owner and manager; (9) Preserve evidence, prepare incident report.

Q286 QUESTION

Nessus scan shows a CVSS 10.0 vulnerability on 50 servers. How do you prioritize remediation?

ANSWER

Prioritization process: (1) Identify exploitability — is exploit public? Is it in CISA KEV? (immediate action if yes); (2) Segment by exposure — internet-facing vs internal (internet-facing first); (3) Segment by criticality — production vs dev, payment vs internal systems; (4) Check for compensating controls — WAF, network isolation reducing exploitability; (5) Plan remediation waves: Week 1 — internet-facing critical systems; Week 2 — internal critical systems; Week 3 — standard systems; (6) Implement compensating control immediately for systems that can't be patched immediately; (7) Verify remediation by rescanning; (8) Track SLA compliance.

Q287 QUESTION

A user reports their machine is connecting to an unknown external IP. What is your investigation process?

ANSWER

Investigation: (1) Identify the connection — what process is making it? (netstat -b or EDR process-network correlation); (2) Check the destination IP — VirusTotal, AbuseIPDB, threat intelligence feeds — known bad?; (3) Check historical connections — was this IP contacted before? When did it start?; (4) Examine the process — legitimate process (svchost) or suspicious? Command line arguments?; (5) Review parent process — what spawned it?; (6) If C2 confirmed: isolate endpoint immediately; (7) Memory image for deeper analysis; (8) Expand scope — are other hosts connecting to the same IP?; (9) Block IP in firewall; (10) Incident report.

Q288 QUESTION

You're hunting for ransomware precursors. What are your hunting queries?

ANSWER

Ransomware precursor hunt queries: (1) Cobalt Strike/RAT beaconing — scheduled connections to single external IP; (2) Credential dumping — LSASS access by non-system processes (Event 10 Sysmon); (3) Network reconnaissance — internal host scanning multiple IPs on SMB (445), RDP (3389); (4) Shadow copy deletion — vssadmin.exe delete shadows; (5) Backup interference — net stop 'backup' or taskkill of backup processes; (6) Lateral movement — PsExec, WMI remote execution across hosts; (7) Privilege escalation — new local admin account creation; (8) LOLBin usage — certutil.exe, bitsadmin, mshta.exe with unusual arguments.

Q289 QUESTION

How do you handle a suspected insider threat?

ANSWER

Insider threat investigation: (1) DO NOT alert the suspect – covert investigation; (2) Involve HR and Legal immediately before any action; (3) Gather evidence covertly: enable enhanced audit logging, review DLP alerts, check data access logs, email gateway logs; (4) Establish timeline – when did anomalous behavior start?; (5) Quantify data accessed – what was taken? Business impact?; (6) Check for exfiltration indicators – email to personal account, USB use, cloud uploads, printing; (7) Document evidence chain of custody; (8) HR/Legal decision on next steps (termination, law enforcement?); (9) Disable access upon departure.

Q290 QUESTION

A web application vulnerability scan shows SQLi. How do you validate and report it?

ANSWER

SQLi validation and reporting: (1) Validate the finding – manually reproduce in safe test environment (not production with live data); (2) Determine impact – read-only (SELECT) or write (INSERT/UPDATE/DELETE) or RCE (xp_cmdshell)?; (3) Identify affected data – what tables accessible?; (4) Screenshot evidence; (5) Rate severity using CVSS (likely High-Critical based on data exposure); (6) Report: title (SQL Injection in login endpoint), CVE reference if applicable, CVSS score, affected URL/parameter, reproduction steps, business impact (attacker can extract all customer data), remediation (implement parameterized queries), verification (rescan after fix); (7) Escalate to development with 24h SLA for critical.

Q291 QUESTION

How do you build a threat hunting program from scratch?

ANSWER

Building a hunt program: (1) Assess current maturity – what data do you collect? What SIEM/EDR do you have?; (2) Define scope – what assets and threats are in scope?; (3) Threat profiling – which threat actors target your sector? Their TTPs?; (4) Identify data sources – ensure endpoint, network, and identity telemetry available; (5) Create first hunt hypotheses from threat intel; (6) Document hunt process – hypothesis, data sources, queries, findings; (7) Automate successful hunts as SIEM correlation rules; (8) Report findings – measure hunts by hours invested vs. true positives found; (9) Build hunt library over time; (10) Train analysts – hunting is a skill developed with practice.

Q292 QUESTION

A log analysis exercise – firewall shows blocked traffic from internal IP to Tor. What next?

ANSWER

Tor connection investigation: (1) Identify the internal host – which system, which user?; (2) Timeline – when did Tor connections start? What preceded them (malware install, phishing click)?; (3) EDR check – what process is generating Tor traffic?; (4) Is this policy violation only (user installed Tor browser) or malware C2 (many malware use Tor for C2 persistence)?; (5) Memory and process analysis – is Tor a standalone browser or DLL injected in another process?; (6) Check for other anomalies from the same host – credential access, lateral movement, data access; (7) Isolate host if C2 suspected; (8) Policy violation: HR engagement + remediation; Malware: full IR.

Q293 QUESTION

How do you create a detection use case from a new threat intelligence report?

ANSWER

TI to detection workflow: (1) Receive TI report on new campaign; (2) Extract IoCs – IPs, domains, hashes, URLs; (3) Extract TTPs – map to MITRE ATT&CK; techniques; (4) For IoCs: import to SIEM watchlists/threat intel platforms & automatic alerting when IoC observed; (5) For TTPs: design behavioral detection rules for each technique (example: T1003 Credential Dumping & SIEM rule for LSASS access by non-system processes); (6) Test rules against historical data – any false positives?; (7) Deploy to SIEM; (8) Hunt retroactively – search historical logs for the IoCs (attacker may already be present); (9) Document in threat library.

Q294 QUESTION

How do you measure the effectiveness of your security monitoring?

ANSWER

Security monitoring effectiveness metrics: (1) Detection coverage — % of MITRE ATT&CK; techniques with detection capability; (2) Detection rate — simulated attacks detected/total (BAS platform measures this); (3) False positive rate — FP/(FP+TP) per data source (target <20%); (4) MTTD — from compromise to detection; (5) Alert quality — % of alerts that result in true positives; (6) Analyst time per alert — efficiency metric; (7) Log source coverage — % of assets sending logs to SIEM; (8) Hunt findings per hunt hour — measure hunt productivity. Review quarterly, improve low-performing areas, report trends to management.

Q295 QUESTION

How do you write a security findings brief for executive leadership?

ANSWER

Executive brief structure: (1) Lead with business risk — 'Three critical vulnerabilities discovered that could allow attackers to access payment data for 2M customers'; (2) Current status — what's been found, what's being done; (3) Business impact in financial terms — 'Estimated breach cost: \$45M based on industry benchmarks'; (4) Timeline — when will it be fixed?; (5) What leadership needs to decide — 'Approving emergency maintenance window requires 2-hour production downtime'; (6) Resource needs — budget, personnel. Avoid technical jargon. Use analogies. Executives care about: brand, revenue, compliance, liability. NOT CVE IDs or CVSS scores.

Q296 QUESTION

How do you conduct a post-incident security improvement?

ANSWER

Post-incident improvement process: (1) Timeline analysis — reconstruct from initial access to recovery; (2) Detection gap analysis — where did detection fail? What would have caught it earlier?; (3) Response gap analysis — where did response slow down? Missing playbook? Tool access issue?; (4) Prevention analysis — what would have prevented the incident?; (5) Prioritized remediation list — each gap has an owner, timeline, and verification method; (6) Implement new detections — SIEM rules, EDR behavioral rules based on attacker TTPs; (7) Update playbooks; (8) Training — brief all analysts on TTPs used; (9) Report to leadership with metrics (dwell time, MTTD, MTTR); (10) Track improvement in next incident.

Q297 QUESTION

How do you perform threat modeling for a new application?

ANSWER

Application threat modeling workshop: (1) Assemble team — developer, architect, security analyst, product owner; (2) Define scope — what system are we modeling? (draw DFD); (3) Identify trust boundaries — where does data cross trust zones?; (4) Apply STRIDE per trust boundary — Spoofing, Tampering, Repudiation, Information Disclosure, DoS, Elevation of Privilege; (5) For each threat: likelihood, impact, existing controls, residual risk, recommended mitigations; (6) Prioritize mitigations; (7) Create security requirements for development; (8) Re-model after major architecture changes. Tools: Microsoft Threat Modeling Tool (free), OWASP Threat Dragon, Miro/Confluence for documentation.

Q298 QUESTION

How do you build a vulnerability management program from scratch?

ANSWER

VM program setup: (1) Asset inventory — discover all assets (Nmap, cloud APIs, CMDB); (2) Select scanning tool — Nessus, Qualys, Rapid7 InsightVM; (3) Deploy infrastructure — scanner, credentials for authenticated scanning; (4) Define scanning schedule — scope, frequency per asset criticality; (5) Establish prioritization framework — CVSS + EPSS + business criticality; (6) Define SLA — Critical 24h, High 7 days, Medium 30 days, Low 90 days; (7) Integrate with ticketing (Jira/ServiceNow) for remediation tracking; (8) Define exceptions process; (9) Executive reporting — monthly vulnerability dashboard; (10) Measure progress — track open critical count, MTTP, SLA compliance trend.

Q299 QUESTION

How do you analyze a suspicious email attachment safely?

ANSWER

Safe email attachment analysis: (1) DO NOT open on a production machine; (2) Extract file without opening — copy to isolated analysis VM (no network access or sandboxed network); (3) Calculate hash — check MD5/SHA-256 against VirusTotal; (4) Analyze with static tools — strings.exe, pdfid.py (PDF), olevba.py (Office macros); (5) Detonate in automated sandbox — Any.run, Hybrid Analysis, Cuckoo (with snapshots for clean reset); (6) Analyze sandbox output — C2 connections, file drops, registry changes; (7) Extract IoCs from analysis; (8) Block IoCs (IP, domain, hash) in security tools; (9) Search email gateway for same attachment sent to others; (10) If malicious — initiate incident response for any recipients who may have opened it.

Q300 QUESTION

How do you prioritize a security backlog?

ANSWER

Security backlog prioritization framework: (1) Risk scoring — combine severity (CVSS/business impact), likelihood (exploitability, threat intelligence), and effort (hours to fix); (2) Quick wins — high risk, low effort items go first; (3) Compliance deadlines — items required for upcoming audit take priority; (4) Business alignment — items blocking critical business initiatives get elevated; (5) Dependency mapping — fix root causes before symptoms; (6) Threat intelligence — prioritize items matching active threat campaigns against your sector. Tools: JIRA with custom priority scoring, risk registers with calculated scores. Present prioritized backlog to leadership quarterly for visibility and resource allocation decisions.